

CEN/CLC/JTC 13

Date: 2026-05-12

prEN 40000-1-2

Secretariat: DIN

WI Number: JT013089

**Cybersecurity requirements for products with digital elements -
Part 1-2: Principles, product risk management, and lifecycle
activities**

ICS: 35.030

CCMC will prepare and attach the official title page.

Contents.....Page

European foreword.....	Error! Bookmark not defined.
Introduction	Error! Bookmark not defined.
Scope.....	Error! Bookmark not defined.
Normative references.....	Error! Bookmark not defined.
Terms and definitions.....	Error! Bookmark not defined.
Application of this document	Error! Bookmark not defined.
Product cybersecurity principles	Error! Bookmark not defined.
Rationale and Guidance.....	Error! Bookmark not defined.
Risk-based approach to product cybersecurity.....	Error! Bookmark not defined.
Product security by design.....	Error! Bookmark not defined.
Secure by default product.....	Error! Bookmark not defined.
Transparency in product security	Error! Bookmark not defined.
Product cybersecurity risk management activities	Error! Bookmark not defined.
Rationale and guidance	Error! Bookmark not defined.
Product context	Error! Bookmark not defined.
Risk acceptance criteria	Error! Bookmark not defined.
Product cybersecurity risk assessment.....	Error! Bookmark not defined.
Product cybersecurity risk treatment.....	Error! Bookmark not defined.
Product cybersecurity risk communication	Error! Bookmark not defined.
Product cybersecurity risk review	Error! Bookmark not defined.
Product cybersecurity lifecycle activities	Error! Bookmark not defined.
Rationale and Guidance.....	Error! Bookmark not defined.
Product cybersecurity planning.....	Error! Bookmark not defined.
Product cybersecurity requirements	Error! Bookmark not defined.
Cybersecurity architecture and design.....	Error! Bookmark not defined.
Secure implementation	Error! Bookmark not defined.
Cybersecurity verification and validation	Error! Bookmark not defined.
Secure production and distribution.....	Error! Bookmark not defined.
Product cybersecurity monitoring and issue management.....	Error! Bookmark not defined.
defined.	
Planning for secure decommissioning.....	Error! Bookmark not defined.
Third-party component cybersecurity management.	Error! Bookmark not defined.
(informative) Coherence with vertical standards	Error! Bookmark not defined.
(informative) Relationship between this European Standard and the essential cybersecurity requirements of Regulation (EU) 2024/2847	Error! Bookmark not defined.
(informative) Accessible and inclusive cybersecurity.....	Error! Bookmark not defined.
(informative) Interaction of the risk management concepts and activities	Error! Bookmark not defined.
Bibliography	Error! Bookmark not defined.

European foreword

This document (prEN 40000-1-2:2025) has been prepared by Technical Committee CEN/CLC/JTC 13 "Cybersecurity and Data Protection", the secretariat of which is held by DIN.

This document is currently submitted to the CEN Enquiry.

This document has been prepared under a standardization request addressed to CEN, Cenelec, and ETSI by the European Commission. The Standing Committee of the EFTA States subsequently approves these requests for its Member States.

Introduction

EN 40000-1-2 is part of a set of standards requested by standardization request M/606 to support CRA (Regulation (EU) 2024/2847) compliance that have the following structure:

- Horizontal standards for cybersecurity requirements relating to the properties of products with digital elements, including:
 - EN 40000-1-1, Cybersecurity requirements for products with digital elements - Part 1-1: Vocabulary;
 - EN 40000-1-2, Cybersecurity requirements for products with digital elements - Part 1-2: Generic Cybersecurity Principles, Product Risk Management Element and Product Lifecycle Activities for Cyber Resilience. (this document);
 - EN 40000-1-3, Cybersecurity requirements for products with digital elements - Part 1-3: Vulnerability Handling;
 - EN 40000-1-4, Cybersecurity requirements for products with digital elements - Generic Security Requirements.
- Vertical standards for cybersecurity requirements relating to the properties of products with digital elements covering product category specific requirements and requirements on vulnerability handling.

This document specifies general cybersecurity principles and general risk management activities for all products with digital elements, hereafter also referred to as 'products'.

For the purposes of this document, all references to the term 'product' includes Remote Data Processing Solutions (RDPS) where applicable. Any explicit reference to RDPS is provided solely to prompt consideration of possible RDPS-specific aspects.

EN 40000-1-2 is tied to the first essential requirement of the CRA on which all other requirements are built. As such EN 40000-1-2 has ties to the work done in EN 40000-1-3 and EN 40000-1-4.

This document can be used by manufacturers of the "default" product category for which vertical standards are not available as a basis for the risk assessment. The combination of the EN 40000-1-2, the EN 40000-1-3 and the EN 40000-1-4 can serve as a basis for self declaration under CRA Annex VIII Part I based on Module A.

1 Scope

This document specifies generic cybersecurity principles, baseline requirements for cybersecurity risk management, and cybersecurity risk management activities for products with digital elements to reduce consumer risks. This document covers the full product lifecycle to ensure and maintain an appropriate level of cybersecurity based on the risks from design to end of support and decommissioning.

This document's baseline requirements for cybersecurity risk management also form a framework to support the development of coherent product category specific harmonized standards (vertical standards) under the standardization request M/606 (REF).

This document:

- specifies generic cybersecurity principles applicable to product cybersecurity which meet the needs of the full range of relevant interested parties;
- specifies baseline requirements for the management of cybersecurity risks;
- specifies requirements on activities that can be applied to ensure an appropriate level of cybersecurity during the product lifecycle;
- provides guidance and requirements for product category specific standards in order to facilitate a harmonized approach.

This document does not provide specific activities and requirements demanded for vertical standards.

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

prEN 40000-1-1, *Cybersecurity requirements for products with digital elements — Vocabulary*
M/606 C(2025) 618

3 Terms and definitions

For the purposes of this document, the terms and definitions given in Regulation (EU) 2024/2847 (CRA), prEN 40000-1-1 and the following apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <http://www.iso.org/obp>
- IEC Electropedia: available at <http://www.electropedia.org/>

4 Application of this document

This document contains 3 main clauses.

Clause 5 is an informative clause that presents generic cybersecurity principles for products seeking alignment with the CRA that, when applied, can lead to an appropriate level of product cybersecurity over all stages of the product lifecycle.

This clause is split into the principle, which due to its high-level nature is hard to assess, and guidance, which includes typically used or applied steps or techniques that are related to the implementation of the principles.

Both Clause 6 and Clause 7 provide information on how to act on the principles of Clause 5. Both clauses follow the same structure and contain informative and normative elements. These clauses both start with an informative rationale and guidance clause followed by topical subclauses that are structured as follows.

Table 1 — Structure of Clause 6 and Clause 7

Sub-subclause title	Normative or informative	Rationale
Rationale and Guidance	Informative	This subclause acts as a summary and typically contains information useful for enacting the requirements. However, since it can be the case that this information is not fully horizontally applicable it is an informative section.
Input	Normative	This subclause contains the expected information deemed needed to complete the requirements adequately, as such it is normative.
Requirement	Normative	This subclause contains the requirements of the related activity.
Output	Normative	This subclause describes the expected output of a clause. It is normative as output is how activities are documented.
Assessment Criteria	Normative	The assessment criteria are normative and typically contain a check to see if the output is of sufficient quality.

Clause 6 presents a generic framework for managing product cybersecurity risks and the requirements for appropriate cybersecurity risk management. It sets requirements to relevant activities of cybersecurity risk management, which can be used throughout the product lifecycle and repeated as necessary.

Clause 7 provides generic requirements for cybersecurity activities during the product lifecycle, including activities related to design, development, production, maintenance and Decommissioning. These activities are process-agnostic and can be applied across different development methodologies. They can be performed concurrently or in varying order, depending on the development approach.

Annex A is an informative annex that provides instructions for vertical standards that desire coherence with the framework established by this document.

Annex B is an informative annex that specifies the relationship between this document and the essential requirements of CRA Annex I Part I (1) and (2). It also identifies the normative and informative parts of the standard.

Annex C is an informative annex that contains information to support manufacturers in developing products that are both secure and accessible to all users and those relevant interested parties impacted by the use of the product.

Annex D is an informative annex that explains how the various clauses and concepts in this standard interact with each other and with other standards in the prEN 40000-1 series.

5 Product cybersecurity principles

5.1 Rationale and Guidance

This clause establishes an informative overview of generic cybersecurity principles applying to the design, development, and production of products with digital elements. It establishes the foundation for risk management activities Clause 6 and lifecycle activities Clause 7 detailed in this document that contribute to appropriate cybersecurity throughout all stages of the product lifecycle.

5.2 Risk-based approach to product cybersecurity

5.2.1 Principle

A risk-based cybersecurity approach for products means that appropriate controls are implemented by the manufacturer during the product lifecycle to address relevant cybersecurity risks to persons, organisations and society.

5.2.2 Rationale and guidance

The risk-based approach bases the cybersecurity controls on the identified risks and ensures that the product controls are appropriate for the risk, and are fit for the intended purpose and reasonably foreseeable use (IPRFU) as well as other factors considered in the product context (Clause 6.2).

The risk-based approach uses the dimensions of impact (magnitude of loss or disruption caused by an incident) and likelihood of occurrence (of an incident) to characterize the risk.

Implemented cybersecurity controls (e.g. constraints for the operational environment) can change the risk by altering the impact or likelihood, or both.

As set out in this standard, a risk-based approach to product cybersecurity is an iteration of activities throughout the product lifecycle, and includes:

- establishing the product context (Clause 6.2);
- establishing risk acceptance criteria (Clause 6.3);
- conducting a risk assessment (Clause 6.4);
- applying risk treatment (Clause 6.5);
- communication about risks (Clause 6.6);
- risk monitoring and review (Clause 6.7);

Following the risk treatment and the application of appropriate risk mitigations, any (residual) cybersecurity risk is determined to be acceptable from the perspective of potential impact.

5.3 Product security by design

5.3.1 Principle

In the domain of cybersecurity, the principle of **security by design** means that a product is **designed, developed, produced, and maintained** in a way that integrates cybersecurity measures from the concept phase throughout the entire product lifecycle.

5.3.2 Rationale and guidance

Product security by design ensures that cybersecurity is treated as a fundamental aspect of the design in all its parts, and it emphasizes that **cybersecurity is not regarded as an element to be added later**.

The security by design principle aims to create more secure products that are better equipped to **withstand cyberthreats by applying cybersecurity techniques or best practices during design** (Clause 7.4), **development** (Clause 7.5) and **production** (Clause 7.6). This principle is closely linked to the risk-based approach (Clause 5.2) as the selection of suitable techniques and best practices depends on the **cybersecurity requirements** (Clause 7.3) identified on the basis of the risk assessment (Clause 6).

Techniques and best practices of the product security by design principle can include but are not limited to:

- **Least privilege:** Ensuring that access to resources is limited to the minimum necessary for the execution of the intended functionality.
- **Attack surface minimization:** Minimize the number of attack vectors and entry points that an attacker could exploit. For example, in the context of product design this can be achieved by removing unnecessary interfaces.
- **Defence in depth:** Implementing multiple layers of cybersecurity controls to protect the product's cybersecurity such that if one line of defence is compromised, additional layers exist as a backup to ensure that threats are stopped.
- **Secure coding practices:** Systematic and continuous use of coding principles and best practices to avoid or detect common causes for defects and weaknesses. For example, this is typically achieved using programming language **specific secure coding rules** and practices or by using **tools to detect security issues** in programming code.
- **Do not rely on security by obscurity:** Avoid using cybersecurity controls that rely on the secrecy of design details or implementation information, but instead rely on established cybersecurity measures and best practices. For example, avoid generating passwords using a secret algorithm that exclusively relies on public information as seed material.
- **User-centric design:** Designing products considering the user needs and behaviours in the context of their **intended purpose and reasonably foreseeable use**, throughout the product lifecycle. **Appropriate controls keep users secure whilst minimising friction to avoid the incentive for security control circumvention**. Examples include considering accessibility aspects in the secure design of the product and informing users of the availability of security updates.
- **Lifecycle management:** Implement cybersecurity controls addressing the entire product lifecycle, including design, development, **production**, deployment, operation and **decommissioning**. For example, manufacturers ensure the product is secure by default at

market placement and provide security updates during the defined support period, as well as by providing an option to securely decommission the product.

5.4 Secure by default product

5.4.1 Principle

The principle of secure by default for cybersecurity means that the default configuration of the product is secure for its intended purpose and reasonably foreseeable use, and intended operational environment at the time the product is made available on the market.

5.4.2 Rationale and guidance

A secure by default configuration helps to protect users, especially those who do not have the technical knowledge to implement or configure cybersecurity controls on their own, as it minimizes security risks without requiring explicit user action and thereby reduces the likelihood of human error that can lead to vulnerabilities. This is especially relevant to the deployment or installation by ordinary or vulnerable users (see 6.2.1.6). The secure by default approach supports users in the implementation of their cybersecurity responsibilities within the product.

This approach significantly enhances the overall security of the product and its users. While "Secure by Design" (5.3) focuses on embedding security throughout the development process, "Secure by Default" (5.4) specifically addresses the state of the product when it is made available on the market.

Since the threat landscape can evolve after a product is placed on the market, it is important that products can receive security updates, when necessary, in a manner appropriate to their intended purpose and reasonably foreseeable use.

Not all best practices listed below will be applicable to every product. Following a risk-based approach, and depending on their relevance to the specific product, best practices can include but are not limited to:

- Providing secure default configurations for all security-relevant settings;
- Enabling security features by default rather than requiring user action;
- Disabling all non-essential network services and interfaces on first activation of the product by the user;
- Updating the product to its most recent secure version upon first installation;
- Disabling remote administration by default;
- Making telemetry/analytics opt-in for consumers and contractual opt-in for business users;
- Providing an easy action for "Reset to secure defaults";
- Requiring explicit user action to deviate from secure defaults and warning the user when they are configuring a product in a manner that deviates from the secure default state;
- Applying update mechanisms that allow recovery from partial or failed installations (a rollback to a secure state);

- Implementing mechanisms to prevent the unauthorized installation of older, vulnerable software versions (anti-rollback);
- Clearly documenting any security-relevant configuration options and their implications; and,
- Accommodating accessibility needs where necessary, managing risks through appropriate cybersecurity controls.

NOTE Be aware that conflicts may result from the integration of accessibility features in a secure by default product design. Please refer to Annex C for more information on accessible and inclusive cybersecurity.

An opt-out for the secure by default state of the product is possible in some business-to-business cases, such as for tailor-made products, or in any case where there is a verifiable agreement with the end-user and the opt-out is justifiable.

For some products, such as custom solutions or if the product is designed for single use, resetting to the default state might not be technically possible.

In any of the aforementioned cases, users are to be given appropriate information related to the risks.

5.5 Transparency in product security

5.5.1 Principle

Transparency means making adequate and relevant cybersecurity information about a product available to the relevant interested parties (e.g. users, integrators, supply-chain actors) so that the product can remain secure.

5.5.2 Rationale and guidance

Effective and transparent communication is critical for informing and involving relevant interested parties in risk treatment. Appropriate transparency is necessary for informed decision-making related to ensuring and maintaining cybersecurity.

The principle of transparency refers to communicating and making cybersecurity information available to relevant interested parties in an accessible and useable format, to help achieve and maintain the cybersecurity of the products.

Appropriate transparency is not just about sharing information about the risks, but also considers the needs of relevant interested parties, including accessibility requirements (Annex C). This addresses aspects such as risks related to incorrect or incomplete interpretation of shared information.

Not all relevant interested parties require access to the same information. An integrator and a user both need information on how to securely use the product, but the integrator may require much more detailed information on how to securely incorporate the product.

Transparency can include but is not limited to relaying information related to:

- requested information and instructions to the user;
- requested content of the technical documentation;

- the availability of updates;
- the risks involved with unduly delayed updates;
- the current security state of the product;
- relevant risks, the risk status and potential mitigations; and,
- information in case of an incident.

It is best practice to ensure communication is available in alternative forms to enable access to the information for a wide range of users. This can be done by adding manuals to physical products but also by ensuring that the information can be accessed online.

6 Product cybersecurity risk management activities

6.1 Rationale and guidance

The management of risks applies to all phases of the product lifecycle, including design, development, production, maintenance and decommissioning to ensure an appropriate level of cybersecurity with respect to its intended purpose and reasonably foreseeable use, until the end of the support period.

This clause describes generic activities to manage risks related to the product that can be applied systematically and at any point in the product lifecycle. Changes in circumstances, including substantial modifications to the product design or changes in the threat landscape throughout the product lifecycle, may trigger repetition of some elements of the risk management activities (in particular the risk assessment), to ensure risk remains within the bounds of the risk acceptance criteria as defined below.

Management of product cybersecurity risks includes the following activities:

- establishing the product context according to 6.2;
- establishing the product cybersecurity risk acceptance criteria according to 6.3;
- performing an assessment of the product cybersecurity risks according to 6.4;
- performing appropriate treatment of the product cybersecurity risks according to 6.5;
- communicating the residual product cybersecurity risks according to 6.6;
- reviewing the product cybersecurity risks according to 6.7.

NOTE Harmonized vertical standards can provide risk management elements and methods to define and measure the risks associated with those specific products. The use of harmonized vertical risk management activities is justified and aligned with the state of the art as established by that standard.

6.2 Product context

6.2.1 Product context elements

6.2.1.1 Rationale and Guidance

Establishing the product context determines the starting point for the assessment and treatment of risks related to the product. This is an iterative activity, as changes to the product or its context need to be reviewed during the product lifecycle.

The elements of the product context are described below.

6.2.1.2 Product intended purpose and reasonably foreseeable use

The intended purpose and reasonably foreseeable use of the product is essential to establish the scope and context for identifying risks.

NOTE 1 Intended purpose and reasonably foreseeable use is defined in the CRA.

NOTE 2 Intended purpose contains the conditions of use.

NOTE 3 Additional information on the intended purpose and reasonably foreseeable use can be found in section 2.8 of the 'Blue Guide' on the implementation of EU product rules 2022 (2022/C 247/01) [0](#).

NOTE 4 In the intended purpose and reasonably foreseeable use, the accessibility of the product, including the use of Assistive Technology is considered.

6.2.1.3 Product functions

The product's functions are those specified by the manufacturer and provided when the product is used according to its intended purpose. This can also include:

- features which fulfil the defined cybersecurity properties, e.g. functions that protect the product, and the health and safety of the user; and,
- the ability to configure the product.

6.2.1.4 Product operational environment

The product's operational environment refers to the conditions and environment the product has been designed for as part of its intended purpose.

The product's operational environment significantly influences both the likelihood and the potential impact of cybersecurity incidents caused by related vulnerabilities. It can also include existing measures that mitigate certain risks. As such, the operational environment plays an important role in the identification, assessment, and appropriate treatment of risks throughout the product lifecycle.

A description of a product's operational environment can, among other aspects, include:

- the networks in which the product is intended, or can reasonably be foreseen, to be used, including the networks' relevant cybersecurity properties;
- the system into which the product is intended, or can reasonably be foreseen, to be integrated, together with other hardware and software components, including the expected relevant cybersecurity properties of that system;

- the physical surroundings where the product is intended, or can reasonably be foreseen to be operated in, including relevant cybersecurity properties;
- the compatibility of the product with Assistive Technology where relevant (Annex C), and;
- people and domesticated animals that are external to the product (i.e. they do not use or are not connected to it but they can still influence it or trigger some of its functions).

The operational environment can include physical and logical access levels. Both physical and logical access may be characterised as, for example, public, limited, or controlled, whereby:

- Public access has no meaningful restrictions;
- Limited access includes some restrictions, and;
- Controlled access allows access only for authorised entities.

NOTE 1 For any RDPS, the operational environment typically contains information on connectivity, expected availability, data handled, its users, managed data, expected uptime and any constraints.

NOTE 2 Other systems and people external to the product or the user of the product can still influence or trigger some of the product functions, they too are part of the operational environment.

NOTE 3 Identifying the product operational environment in terms of the distribution of cybersecurity functions helps identify what the product can reasonably expect in terms of security controls from its environment and what the environment expects from the product.

NOTE 4 Product use can occur in different situations. When considering an ordinary user of software on a laptop, both secure locations, such as in the home or office, and less secure places, such as on public transport during commuting, can be in scope.

6.2.1.5 Product architecture overview

The product architecture overview includes at least the key components of the product as well as the product interfaces and dependencies. It is a high-level overview of the components of a product including its RDPS.

Integrating components can introduce cybersecurity risks. The dependency on these components and the (cybersecurity) features they provide or need are a key aspect to consider in the risk assessment.

NOTE 1 Where the product contains RDPS, the product architecture overview describes the relation where RDPS plays a role in delivering any stated product function.

NOTE 2 Some products may interact with assistive technology. This interaction can be displayed in the product architecture overview.

6.2.1.6 Product user description

The product's user is any natural or legal person or organisation intended to interact with the product. This can include the use of a product as a component in another product. The description outlines the user's reasonably foreseeable level of experience, trustworthiness, knowledge and ability to securely use the product. The use of a product can include installation, operation, integration, maintenance and decommissioning of the product.

Users can be reasonably divided into different classifications. These classifications can include:

- Vulnerable users, these are users who are children, users with disabilities or users of assistive technology. These users can still be capable of having the right knowledge but may be unable to act on that knowledge. Their limitations may also prevent them from accessing information and instructions to the user. These users may need additional accessibility features or warrant a higher level of protection. Annex C contains more details on accessible and inclusive cybersecurity.
- Ordinary users. (SOURCE [Error! Reference source not found.](#)) An ordinary user is not assumed to have any product and specifically security specific skills or knowledge and is uninstructed beyond the information and instructions to the user. These users cannot be assumed to have skills to mitigate risks themselves.
- Instructed users. (SOURCE [Error! Reference source not found.](#)) An instructed user is assumed to have been instructed and trained, or supervised by a skilled user regarding the product and its security properties. An instructed user is capable of understanding how the product is installed, operated, and maintained.
- Skilled users. (SOURCE [Error! Reference source not found.](#)) A skilled user is assumed to have specialized training and enhanced experience in the product and its security properties. A skilled user has profound knowledge how the product is installed, operated, and maintained. A skilled user is capable of assessing potential security limitations and has a greater ability to mitigate risks themselves.

Users have their own needs related to the use of the product. These needs can include the confidentiality of their data, protection against fraud, their health and safety, and potential support for assistive technology. Identification of these needs is fundamental to understanding which risks impact the user.

NOTE 1 A product can be operated and used by different kinds of user groups in different contexts. For example, software can be centrally administered by a professional IT department (skilled user) providing support and it can be used by an ordinary user.

NOTE 2 Additional information on 'end-user' can be found in section 3.8 of the 'Blue Guide' on the implementation of EU product rules 2022 (2022/C 247/01).

6.2.1.7 Distribution of security functions

The distribution of cybersecurity functions is an overview of functions that can include:

- provided by the product for its own use;
- required by the product from its digital/physical environment;
- provided by the product and used by other products in the products environment.

NOTE 1 The security functions provided by the product may not be known at the start. This is an iterative aspect of the risk-based approach as adding controls to the product changes the product context.

NOTE 2 Security functions provided by a product are included in the product documentation. An integrator is expected to select the appropriate components.

6.2.2 Input

The input should include documentation about:

- product and customer expectations; and,
- related market segments and products.

6.2.3 Requirement

[RMA-01-RQ-01] The product context shall be identified and documented including:

- the product's IPRFU;
- the product's functions;
- the product's operational environment of use;
- the product's architecture overview;
- the product's user description; and,
- distribution of security function, if available.

[RMA-01-RQ-02] If the product has an RDPS, it shall be considered in the determination of the product context.

6.2.4 Output

The output shall include documentation containing the product context as per clause 6.2.3.

6.2.5 Assessment criteria

Check if the documentation of the product context exists.

Assess whether the product context from 6.2.4 meets the requirements from 6.2.3.

Assess whether the documented product context from 6.2.4 is appropriate for the product

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

6.3 Risk acceptance criteria

6.3.1 Rationale and guidance

Establishing the risk acceptance criteria for products is a necessary step to determine if risk treatment is needed and if applied risk treatment has been sufficient or if more action is needed.

These criteria are established based on the product's context (6.2). The risk acceptance criteria are typically determined as a first step of the risk assessment, although they can be reviewed and updated during later stages of development as they are influenced over time by changes in the state of the art, the threat landscape, and other relevant factors. Additionally, risk acceptance criteria can vary depending on the phase of the product lifecycle and that of its components, such as by obsolescence or deprecation. It is important to re-evaluate risk acceptance criteria when necessary.

Some circumstances justify deviating from these criteria for individual risks. Examples include situations where the user explicitly accepts certain risks, such as those introduced in tailor-made products to ensure compatibility with the customer's environment, or through other contractual agreements. Communicating the relevant transferred residual risk of the product is essential to ensure that risk is mitigated appropriately through the supply chain or when used by the end user (see clause 6.6 risk communication).

These criteria can typically be based on a number of common factors such as:

- The intended purpose and reasonably foreseeable use, as well as the conditions of use.
- Regulatory factors. Legislation affecting the product can influence the degree by which a specific risk is acceptable. Examples include privacy or safety legislation.
- Supply chain considerations such as:
 - Contractual agreements, expectations of relevant interested parties or existing business practices provided they align with applicable legislation;
 - Downstream integrators. Some risks cannot be addressed as they are related to the products intended purpose. Those risks can be shared or transferred to downstream integrators of the product as a component into their own products; and,
 - Reasonable expectations. Expectations reasonable to the product context in terms of environmental controls and user expertise for configuration can play a role in risk acceptance. This is a fundamental aspect of risk sharing.
- The nature of the risks such as:
 - The health and safety of the user or other individuals affected by the product;
 - The severity of the impact and likelihood of the risk and any cascading effects;
 - Inherent risks, for some products, certain risks are inherent and cannot be mitigated or avoided without compromising function. These functionally necessary risks to the product may be considered acceptable under the risk acceptance criteria, taking into account the product context and communication.
- The nature of the product such as:
 - Operational environment factors. The operational environment associated with the products' IPRFU can have a mitigating or magnifying effect on the product's risk;
 - the online hosting platform or product related RDPS.
- The estimated number of products on the market. The quantity of products produced can affect the impact of an exploited vulnerability in the product if multiple products are exploited simultaneously. Risks may be acceptable when considering a single product, but when considering a large number of products this aggregated risk may become unacceptable.
- The user, the estimated number of impacted users and their capability to mitigate risk further as per the user description.

NOTE 1 If applicable legal requirements are identified through a legal applicability assessment, this assessment precedes the product cybersecurity risk assessment (Clause 6.4) and informs the

establishment of the risk acceptance criteria. It does not form part of the product cybersecurity risk assessment (Clause 6.4) or the product cybersecurity risk treatment activities (Clause 6.5).

NOTE 2 The risk acceptance criteria are based on the product context meaning that although some risks may not be minimized, they might still be acceptable due to risk sharing or transferring in the downstream supply chain or because of other mitigations as a consequence of the intended purpose and reasonably foreseeable use of the product, the users, or the product operational environment.

6.3.2 Input

The input should include expectations of relevant interested parties influencing the risk acceptance criteria.

The input shall include:

- the product context from 6.2; and,
- relevant legal requirements.

6.3.3 Requirement

[RMA-02-RQ-01] The risk acceptance criteria shall be defined, justified for the product context (6.2), and documented considering at least the assumptions and expectations regarding the:

- relevant regulatory factors;
- supply chain considerations;
- nature of known risks; and,
- state of the art.

NOTE Vertical standards can contain risk acceptance criteria to define and measure the risks of a product. For product categories having a vertical standard, the use of a given risk acceptance criteria are justified and aligned to the state of the art in that standard.

6.3.4 Output

The output shall include the product's cybersecurity risk acceptance criteria as defined by 6.3.

6.3.5 Assessment criteria

Check whether the risk acceptance criteria for the product exist.

Assess whether the risk acceptance criteria are:

- based on the user needs;
- are reasonable and justified for the product context (6.2); and,
- meet the requirements stated in clause 6.3.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

6.4 Product cybersecurity risk assessment

6.4.1 Rationale and guidance

The product cybersecurity risk assessment identifies, analyses and evaluates risks based on the product context (6.2) the risk acceptance criteria (6.3).

The activities include:

- identification of the assets and their related cybersecurity properties according to 6.4.2;
- identification of the cybersecurity risks for the product that may affect the assets according to 6.4.3;
- analysis of the cybersecurity risks for the product according to 6.4.4; and,
- evaluation of the cybersecurity risks for the product according to 6.4.5.

NOTE This document does not specify methodologies for a risk analysis, as long as the risk estimation is based on the likelihood of occurrence and the impact after a successful attack resulting from a potential threat. Thus, different approaches and models such as the fishbone model, event tree analysis, fault tree models, attack feasibility ratings or attack potential considerations can be used within the analysis of risks.

6.4.2 Product cybersecurity asset identification

6.4.2.1 Rationale and guidance

Product cybersecurity asset identification determines what is to be protected for the product. When identifying assets, their related cybersecurity properties are also identified. Cybersecurity properties include the confidentiality, integrity, and availability of the assets, or any other properties that may be threatened in a cyberattack.

Assets vary widely, and are intrinsically linked to the product context. They can be related to what the user finds valuable, to bystanders, or to aspects of the product itself. Identified assets can be divided into categories, determining the assets and their relation to the product.

Assets related to the product can include but are not limited to:

- data stored, processed or transmitted by the product (e.g. cryptographic keys/authentication tokens, personal data, financial data, log data);
- functions performed by the product (e.g. the capability to configure the product, the capability to communicate, the integrity of cryptographic protocols); and,
- software and hardware components of the product, and its interfaces.

Assets related to the product's cybersecurity-relevant functions and operational security (supporting assets) can include:

- software and hardware components of the product, including its interfaces;
- updates and patch processes; and,
- the wider system view including the network and adjacent devices.

Examples of assets related to the product user's needs can include:

- the user's health and safety;
- protection of the user's data (for example against manipulation or fraud, or the protection of the user's privacy);
- availability of the product's functions; and,
- the compatibility with assistive technology.

Other factors include assets related to the product environment, for example:

- the network and adjacent devices (physically and digitally);
- the health and safety of other persons or domestic animals; and,
- public interest in general.

NOTE 1 In some cases not all of these assets can be known. For products that are components—such as microcontrollers and microprocessors— part of whose intended purpose is integration into end products, the assets of the end product that can be processed or stored by the component are typically not fully known to the component manufacturer. As such it is important in the risk assessment to ensure the intended purpose of the product is secured appropriately. In the case of microcontrollers, the focus is therefore on the functionality.

NOTE 2 In determining assets and their related cybersecurity properties this process does not limit itself to the protection of the operator of the product. This can extend to the protection of property, the protection of health and safety of legal or natural persons, domestic animals, the environment, and public interest in general as long as this is related to the intended purpose and reasonably foreseeable use.

6.4.2.2 Input

The input shall include the product context from 6.2.

6.4.2.3 Requirement

[RMA-03-RQ-01] The product cybersecurity assets and their cybersecurity properties to be protected shall be identified based on the product context (6.2).

6.4.2.4 Output

The output shall include a list of the product cybersecurity assets and their related cybersecurity properties.

6.4.2.5 Assessment criteria

Check whether a list of the product cybersecurity assets and their related cybersecurity properties exists.

Assess whether the assets and cybersecurity properties from **6.4.2.4** are applicable and representative of the product within the specified product context (**6.2**).

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

6.4.3 Product cybersecurity threat identification

6.4.3.1 Rationale and guidance

Following identification of the assets, product cybersecurity threat identification determines the threats that could affect those assets within the scope of the product context (6.2). Not all threats to a product will result in a risk. Product cybersecurity risk assessment measures if such threats could cause product-related incidents that could lead to compromises of assets and, consequently, lead to product cybersecurity risks.

Threat modelling is a structured approach for identifying threats. Threat modelling can consider, for example, the product lifecycle, how a product functions, reasonably foreseeable misuse, possible threat actors and/or threat events, and identifies threats to the product.

NOTE 1 Examples of threat modelling approaches include frameworks such as attack trees [0](#), PASTA [0](#), STRIDE [0](#), and TARA [Error! Reference source not found.](#)

Standards that require threat modelling include EN IEC 62443-4-1 [0](#), and TVRA [Error! Reference source not found.](#)

NOTE 2 The threat catalogue in [Error! Reference source not found.](#) or comparable sector specific threat catalogues (e.g. MITRE) can be used as input to determine common threats. Information on the product-specific threats can also be acquired from product-specific European Standards (ENs).

Vulnerabilities can lead to a specific type of risk caused by weaknesses in the product that threat actors can exploit. Known vulnerabilities, as can be found in publicly available databases, can lead to risks if exploitation is possible in the product. Awareness of the vulnerabilities in the product is needed in order to address the risks (7.8).

6.4.3.2 Input

The input shall include:

- the assets determined in 6.4.2;
- the product context from 6.2;
- if available, threats related to the product from threat catalogues; and,
- relevant known vulnerabilities.

6.4.3.3 Requirement

[RMA-04-RQ-01] Product cybersecurity threats shall be identified and include:

- targeted asset(s) including their potentially compromised cybersecurity properties (6.4.2);
- cause of the potential compromise of the cybersecurity properties.

6.4.3.4 Output

The output shall include a list containing the product cybersecurity threats.

6.4.3.5 Assessment criteria

Check that a list of product cybersecurity threats exists.

Assess whether the list of product cybersecurity threats is justified for the product context (6.2).

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

6.4.4 Product cybersecurity risk analysis

6.4.4.1 Rationale and guidance

Product cybersecurity risk analysis estimates the likelihood of occurrence (likelihood) and the potential magnitude of loss or disruption (impact) of a potential cybersecurity incident due to the product cybersecurity risks.

The impact and likelihood of a potential cybersecurity incident due to product cybersecurity risk can be expressed in a qualitative or quantitative manner. The assessment is used to define the risks in a consistent way so that an informed decision considering the risk acceptance criteria on risk treatment or risk acceptance is possible.

Both likelihood and impact are estimated from the perspective of the users which are potentially affected by the risk.

Likelihood can consider factors such as discoverability and speed of materialisation of the risk. Some risks can be easily monitored and their exploitation detected by users. In other cases, the user will not be aware of exploitation, or exploitation happens so rapidly that the user is incapable of intervening.

Impact can consider matters such as health and safety, data loss, economic losses to the user and impact on accessibility.

NOTE 1 Threat actors are entities that can intentionally or unintentionally cause harm to the product by exploiting vulnerabilities. They can include external attackers, insiders such as employees or contractors, or even unintended users who gain access to the product.

NOTE 2 EN 18037 supports the concept of risk scenarios and provides guidance on how to conduct risk analysis and evaluation on this basis.

NOTE 3 A qualitative estimation of risks can be performed using risk matrices that map qualitative categories of the likelihood of occurrence and qualitative categories of magnitude of potential loss or disruption to qualitative risk categories.

NOTE 4 A quantitative estimation of risks can be performed using scoring systems that map qualitative categories of the likelihood of occurrence and qualitative categories of magnitude of potential loss or disruption to numerical values.

NOTE 5 Risk can, amongst others, be expressed in terms of categories of risks, and parameters for estimating likelihood of occurrence (like attack feasibility) and magnitude of loss or disruption related to risks.

Vulnerabilities can lead to a specific type of risk caused by weaknesses in the product that threat actors can exploit. Known vulnerabilities, as can be found in publicly available databases, can lead to risks if exploitation is possible in the product. Awareness of the vulnerabilities in the product is needed in order to address the risks (7.8).

NOTE 6 Threat actors are entities that can intentionally or unintentionally cause harm to the product by exploiting vulnerabilities. They can include external attackers, insiders such as employees or contractors, or even unintended users who gain access to the product.

6.4.4.2 Input

The input shall include the list of the product cybersecurity threats from 6.4.3.

6.4.4.3 Requirement

[RMA-05-RQ-01] The likelihood of occurrence of a cybersecurity incident shall be estimated for each identified threat.

[RMA-05-RQ-02] The impact of the potential cybersecurity incidents shall be estimated for each identified threat.

[RMA-05-RQ-03] The scenario of the potential cybersecurity incidents in which the risk exists shall be documented.

6.4.4.4 Output

For each risk from 6.4.3, the following information shall be documented:

- likelihood;
- impact;
- the risk scenario of the potential cybersecurity incidents.

6.4.4.5 Assessment criteria

Check that the output of 6.4.4.4 exists.

Assess whether the output of 6.4.4.4 has been analysed in a consistent manner.

Assess whether the output of 6.4.4.4 meets the requirements of 6.4.4.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

6.4.5 Product cybersecurity risk evaluation and risk acceptance

6.4.5.1 Rationale and guidance

Product cybersecurity risk evaluation compares the identified risk against the pre-established risk acceptance criteria and justifies acceptable (residual) risks.

Risk acceptance is a decision to acknowledge the risk and consciously accept the potential likelihood or impact without taking action to (further) address it. A risk can be deemed acceptable provided it aligns with the predetermined risk acceptance criteria (6.3) .

Any accepted (residual) risk does not vanish; it is shared with the user of the product. This risk might be acceptable because the conditions of use clarify the controls needed to use the product securely within product's intended operational environment. Clear and accessible communication for all (residual) risks that require user action or awareness is fundamental to ensure the security of the product and is conditional to sharing these risks. See clause 6.6.

NOTE 1 Risk sharing does not release a manufacturer of their legal obligations.

NOTE 2 Risk sharing is especially relevant and prevalent for products used as components. For some components, some risks cannot be addressed at the component level; those risks are shared with the user of the product.

EXAMPLE 1 A component or product lacks access controls due to the nature of its functions. In isolation this would be an issue, but when used in the intended operational environment appropriate access controls are instead provided externally. In this case, it is important to clearly communicate that the product is intended to be used in such an environment, whether physical or digital.

EXAMPLE 2 A memory chip does not support confidentiality or integrity of data, and it is left to the integrating solution to implement adequate confidentiality and integrity protection. The risk related to the data to be stored on the memory chip is transferred to the integrator.

NOTE 3 In some cases it may be an appropriate action that the manufacturer organises a recall of a product that is subject of a (severe) risk that is discovered after the product is placed on the market and that cannot be addressed by an action of the (even well-informed) user.

6.4.5.2 Input

The input shall include:

- the product context from 6.2;
- the risk acceptance criteria from 6.3; and,
- the risks determined in 6.4.3 including the analysis from 6.4.4.

6.4.5.3 Requirement

[RMA-06-RQ-01] Each risk shall be evaluated by comparing it with the risk acceptance criteria to determine if the risk is acceptable or requires treatment.

[RMA-06-RQ-02] Risks shall only be accepted when the risks are acceptable according to the risk acceptance criteria.

[RMA-06-RQ-03] Based on the product context (6.2), where mitigation of the risk requires user action or specific operational environments as stipulated in the conditions of use, risks shall only be accepted if the recommended mitigation measures are within the capability of the intended users, depending on their expected knowledge and ability.

[RMA-06-RQ-04] Accepted risks shall be justified.

6.4.5.4 Output

The output shall include:

- the evaluation of the risks determined in 6.4.3; and,
- justification for (residual) risk acceptance.

6.4.5.5 Assessment criteria

Check that the output of 6.4.5.4 exists and considers all risks identified in 6.4.3.

Assess whether the justification for (residual) risk acceptance is aligned with the risk acceptance criteria from 6.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

6.5 Product cybersecurity risk treatment

6.5.1 Rationale and guidance

The aim of risk treatment is to address risks so that the residual cybersecurity risk is acceptable. This can be done in different ways. Typically, risks are managed through risk avoidance, such as by removing the source of the risk altogether, or through risk mitigation, by implementing controls to change either the likelihood or impact related to a risk. For examples of controls refer to [Error! Reference source not found.](#) Introducing constraints on the intended use of the product, for example by restricting the operating environment, is another mechanism that can help modify risks.

Risk avoidance techniques, in particular, can help resolve some classes of vulnerabilities. Examples include:

- by removing unnecessary interfaces;
- by avoiding immature libraries;
- by avoiding unsafe legacy communication protocols; and,
- by avoiding support for external plugins or scripting when not strictly necessary.

Risk avoidance and mitigation typically modify the product, triggering a repeat of the risk assessment. For example, adding controls for risk mitigation can result in changes to existing risks and can add new risks.

If risks cannot be avoided or mitigated in the product, altering the product context, (e.g. though changing the intended purpose or conditions of use) can be used to make adjustments in the risk acceptance criteria, thereby rendering the risk acceptable.

In some cases, products might contain inherent risks in functionalities that cannot be avoided without compromising the intended use of the product. In other cases, risks can be impossible to mitigate due to the product context, or mitigation without user action might be detrimental to the user. Addressing these risks can require user action. In these cases, it is essential to inform the user of this specific security information to ensure they are aware of the risks and are informed to take appropriate action.

Addressing risks on the user side depends on user context, as not all users are capable of enacting the same activities. As such, the type of risks shared to the user depends fully on the expected capabilities of the user. An example includes when utilising the secure by default principle. Insecure features can be turned off by default unless specifically activated via configuration by the user. Providing the user with a warning or information about the risks is essential. This way the user is aware of and is informed to take appropriate action.

6.5.2 Input

The input shall include:

- the product context from 6.2; and,
- the evaluated risks from 6.4.5.

6.5.3 Requirement

[RMA-07-RQ-01] Each risk found to not be acceptable to the risk acceptance criteria (6.4.5) shall be treated as appropriate to the product context (6.2).

[RMA-07-RQ-02] The risk treatment decision and its rationale shall be documented.

[RMA-07-RQ-03] After risk treatment the risks shall be re-evaluated.

6.5.4 Output

The output shall include the documentation of the risk treatment decision with justification per risk.

6.5.5 Assessment criteria

Check that the output of 6.5.4 exists.

Assess whether the justification for the risk treatment option is aligned with the risk acceptance criteria from 6.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

6.6 Product cybersecurity risk communication

6.6.1 Rationale and guidance

Risk communication refers to providing information on risks related to the product based on the product context.

It is necessary to clearly communicate all relevant risks transferred to the user, as well as the actions and measures expected from the user to mitigate these risks. Where appropriate this communication considers accessibility aspects (e.g. simple language, multi-modal formats). This ensures that the user has the capability to take appropriate actions to mitigate those risks and securely use the product according to the conditions of use.

NOTE Communication needs depend on the relevant interested parties. End users can have impairments that prevent them from accessing this information in written format, or prevents access to the information if it is only available on a website. When dealing with other manufacturers it can be enough to have the information written in a language they are able to understand.

6.6.2 Input

The input shall include:

- the risks relevant to the user from 6.4.5;
- the risk treatment decisions from 6.5.

6.6.3 Requirement

[RMA-08-RQ-01] The communication of relevant risks to users shall be carried out using methods and terminology that meets their communication needs, ensuring that information for consumers is provided in clear, non-technical language, where possible.

[RMA-08-RQ-02] The product risk communication shall consider accessibility aspects (e.g. simple language, multi-modal formats) for the user.

[RMA-08-RQ-03] The communication of the product's risks to user shall include:

- disclosure of circumstances related to the product context and reasonably foreseeable misuse that can lead to significant cybersecurity risks;
- recommended mitigation measures for the user, e.g. the environment for use, integration and operation; and,
- the conditions of use to securely use the product.

6.6.4 Output

The output shall include

- documentation containing the circumstances related to the product context and reasonably foreseeable misuse that can lead to significant cybersecurity risks; and,
- documentation containing the conditions of use, and recommended mitigation measures communicated to the user to securely use the product.

6.6.5 Assessment criteria

Check that the output of 6.6.4 exists.

Assess whether the output of 6.6.4 meets the requirements of 6.6.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

6.7 Product cybersecurity risk review

6.7.1 Rationale and guidance

In order to ensure that appropriate cybersecurity of the product is maintained it is important to review and, if necessary, update the elements of risk management to address potential changes in the threat landscape and state of the art.

Review can be done on a regular basis. The regularity (planned intervals) with which this can take place will depend on the risks and the product context.

This review can be triggered by:

- modifications in the product or in its context;
- the observation that the threat landscape has changed; and,
- cybersecurity testing (7.6) or threat and vulnerability intelligence results (7.8).

NOTE Updating relevant parts of the risk management can include adding or modifying product controls.

6.7.2 Input

The input shall, where applicable, include:

- the product context from 6.2;
- the risks acceptance criteria from 6.3;
- the evaluated risks from 6.4;
- the risk treatment decision from 6.5;
- documentation containing the conditions of use to securely use the product;
- documentation of the cybersecurity V&V results (e.g. test reports) from 7.6; and,
- threat and vulnerability intelligence results 7.8.

6.7.3 Requirement

[RMA-09-RQ-01] Product cybersecurity risk management activities shall be reviewed at planned intervals based on the risk assessment and the product context.

[RMA-09-RQ-02] The review of the risk management activities shall also be performed:

- when the product is subject to a modification that might impact cybersecurity;
- when the product's context changes;
- when the risk acceptance criteria of the product change over the product lifecycle;
- when the product's cybersecurity risk exposure changes (including changes to the threat landscape);
- when a known exploitable vulnerability or actively exploited vulnerability is identified;
- when a severe incident occurs; and,
- when a component becomes obsolete and has an impact on the cybersecurity of the product.

[RMA-09-RQ-03] If impacted, relevant risk assessment documentation of Clause 6 shall be updated.

6.7.4 Output

The output shall include:

- documentary evidence that the review has been done; and,
- if applicable, any relevant updated documentation of Clause 6 .

6.7.5 Assessment criteria

If the review of the risk assessment has been triggered, check that updates of the relevant documentation of Clause 6 exist.

If a review is triggered, assess whether the updates of the relevant documentation of Clause 6 cover the changes needed due to the trigger of the review.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

7 Product cybersecurity lifecycle activities

7.1 Rationale and Guidance

Product cybersecurity lifecycle activities are intended to be process agnostic. There are dependencies between activities: some are prerequisites for others but, with certain development methodologies (including agile approaches), the activities in this clause can be executed concurrently or in various orders. Furthermore, many activities can be revisited at relevant points or regular intervals as a change in one can imply changes in several others.

7.2 Product cybersecurity planning

7.2.1 Rationale and guidance

Product cybersecurity planning involves describing the cybersecurity activities for a product throughout its lifecycle. Relevant activities are found in Clause 6 and Clause 7. Many activities are interrelated. Changes in one activity can affect others.

The rigor of activities planned are dependent on the risks identified in Clause 6. For example, the risk assessment can be used to determine how often to test, or what kind of tests to apply.

The activities described in Clause 7 are common to all development processes although the way they are implemented can differ.

NOTE 1 Planning can include considerations on the roles and responsibilities, as well as ensuring that personnel are adequately trained, as appropriate.

NOTE 2 The product cybersecurity planning is usually documented as a product cybersecurity plan. This is often a living document, which can start off blank but evolves as more information becomes available.

NOTE 3 Some of the planned activities can be implemented in a uniform way across multiple products. In such cases, the product individual planning just refers to an organization wide policy.

7.2.2 Input

The input shall include the output from the product context described in 6.2, once available.

7.2.3 Requirement

[CLA-01-RQ-01] The product cybersecurity planning shall cover at least the applicable activities:

- described in Clause 6, and 7.3 through 7.10.

[CLA-01-RQ-02] For the complete product lifecycle, the activities in the product cybersecurity planning shall:

- be maintained and reviewed on a regular basis; and,
- have their execution tracked.

7.2.4 Output

The output shall include documentation containing the product cybersecurity planning according to the requirements in 7.2.3.

7.2.5 Assessment criteria

Check that the output of 7.2.4 exists.

Assess whether the output of 7.2.4 meets the requirements set in 7.2.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

7.3 Product cybersecurity requirements

7.3.1 Rationale and Guidance

Product cybersecurity requirements, based on the product context and derived from the risk assessment, describe what needs to be implemented. They may be informed by the needs and expectations of the user, manufacturer and other relevant interested parties of the product, but this does not override or redefine regulatory obligations. Additionally, the identification and formulation of product cybersecurity requirements typically consider the traceability, validity, understandability and verifiability of product cybersecurity technical specification as well as the cybersecurity-relevant characteristics of the product's environment during development, production, deployment and maintenance.

The product cybersecurity requirements are managed throughout the product lifecycle and are a foundational input for further activities.

7.3.2 Input

Input shall include:

- the product context from 6.2;
- assessment of product cybersecurity risks from 6.4;
- treatment decision of product cybersecurity risks from 6.5;
- applicable regulatory requirements.

7.3.3 Requirement

[CLA-02-RQ-01] The product cybersecurity requirements shall be specified based on, the product context, the treatment decision of product cybersecurity risks, and applicable regulatory requirements.

NOTE Regulatory requirements can include other regulations such as the GDPR to address data minimisation requirements.

[CLA-02-RQ-02] The product cybersecurity requirements shall be reviewed and when necessary updated when there are changes in any of the listed inputs.

7.3.4 Output

Specified cybersecurity requirements shall be documented.

7.3.5 Assessment criteria

Check that documentation specifying the product cybersecurity requirements from 7.3.4 exists.

Assess whether the documentation of the product cybersecurity requirements from 7.3.4 meets the requirements from 7.3.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

7.4 Cybersecurity architecture and design

7.4.1 Rationale and guidance

The cybersecurity architecture and design of the product are aligned with the cybersecurity requirements as defined in 7.3 and the product context as defined in 6.2, with design decisions both informed by and informing the cybersecurity requirements.

The cybersecurity architecture and design activities include the selection of the appropriate controls to fulfil the cybersecurity requirements as defined in 7.3.

NOTE Examples of catalogues of cybersecurity controls:

- EN 40000-1-4 [Error! Reference source not found.](#) (These controls are related to the essential requirements of the CRA [0](#));
- [Error! Reference source not found.](#);
- [Error! Reference source not found.](#);
- [Error! Reference source not found.](#);
- Vertical standards developed under the standardization request M/606 (REF).

These are merely illustrative examples manufacturers can use other technically appropriate sources to meet the cybersecurity requirements.

Consider, for example, the following aspects for the product cybersecurity architecture and design:

- the trust boundaries between components and subsystems including RDPS, where applicable, to ensure clear separation of privileges and responsibilities, as well as containment;
- the secure interface design, with particular attention to authentication, input validation, and minimization of the exposed attack surface.

Typical artefacts of the cybersecurity architecture and design can include, but are not limited to, design documents explaining the following, where applicable:

- the secure-by-default settings of components;
- the product internal and external interfaces, defining how they are secured;
- data-flow or trust-boundary diagram showing components and subsystem boundaries, indicating, for example, the relation to RDPS;
- availability of product functions;
- ability to separate functional and security updates.

7.4.2 Input

The input shall include:

- cybersecurity requirements from 7.3.4.

7.4.3 Requirement

[CLA-03-RQ-01] The cybersecurity architecture and design of the product shall be specified, including the selection of the appropriate cybersecurity controls to fulfil the cybersecurity requirements from 7.3.

NOTE Cybersecurity architecture and design can consider the cybersecurity principles in accordance with clause 5.3 - security by design and clause 5.4 - secure by default.

[CLA-03-RQ-02] The cybersecurity architecture and design shall ensure that the cybersecurity of the product is maintained during component integration design, including third-party components and RDPS.

7.4.4 Output

The output shall include the documented cybersecurity architecture and design for the product.

7.4.5 Assessment criteria

Check that documentation specifying the cybersecurity architecture and design from 7.4.4 exists.

Assess whether the documentation of the cybersecurity architecture and design from 7.4.4 meets the requirements from 7.4.3.

Assess whether the cybersecurity architecture and design for the product is consistent with the product cybersecurity requirements identified in 7.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

7.5 Secure implementation

7.5.1 Rationale and guidance

Secure implementation activities ensure the development of secure product meets the previously defined cybersecurity requirements from 7.3, as per the cybersecurity architecture and design from 7.4, incorporating the cybersecurity controls. Special considerations for secure implementation include configuring the implementation options of integrated components that may have an impact on the overall cybersecurity of the product.

Activities of secure implementation can include, but are not limited to:

- the maintenance of the Software Bill of Materials (SBOM). The SBOM lists the components used in the software, covering at least the top-level dependencies including 3rd party components, and relevant parts that support efficient vulnerability monitoring;

NOTE 1 For more information on the Software Bill of Materials (SBOM) refer to [Error! Reference source not found.](#)

- managing dependencies and third-party libraries by selecting secure libraries and keeping them up to date as per 7.10;

- the development or use of hardware-based security functions;
- the use of secure coding standards. Manufacturers often use a set of coding standards and guidelines to write secure code. These standards help maintain code quality and consistency, and in avoiding common programming errors that could lead to cybersecurity vulnerabilities. Different rules apply for different programming languages. Secure coding practices include using secure functions, prohibiting hard-coded credentials, and implementing proper error handling;
- the use of secure coding strategies to ensure memory safety, including practices to avoid buffer overflows, memory leaks, and other memory-related vulnerabilities. This can involve using safe programming languages, employing memory management techniques, and utilizing tools for detecting common defects;
- development of the technical documentation as well as information and instructions for users (CRA Annex VII and II(0)).

NOTE 2 The technical documentation and information and instructions to the user may be prepared and updated at various phases in the product lifecycle. In all cases, the documentation must be reviewed for consistency and appropriateness, and therefore in this standard, we assume the activities occur during the implementation phase, with the expectation that the reviews happen during the verification and validation activities. This does not restrict the preparation of these deliverables at other phases.

In some circumstances, the secure implementation activities can result in deviations from the cybersecurity architecture and design documentation, leading to different security behaviour. In the event of such deviations, reviews of the cybersecurity architecture and design documentation, the product cybersecurity requirements and the cybersecurity risk management activities may be triggered.

A secure implementation typically relies on a securely maintained development environment that, amongst other things and where applicable to the risks, design and scope of the product:

- prevents unauthorized access to components and source materials;
- may include software tools for managing, developing and implementing the software and other product-related artefacts;
- manages cryptographic keys and certificates using technology appropriate to their sensitivity.

NOTE 3 The "Agreed Cryptographic Mechanisms (ACM)" by ENISA is considered as the baseline for appropriate technology for managing cryptographic keys and certificates. Also consider the need for Cryptographic Agility to support the transition to Post-Quantum Cryptography (PQC) during the product's support period.

7.5.2 Input

The input shall include:

- cybersecurity requirements from 7.3.4;
- cybersecurity architecture and design from 7.4.4;
- documentation relating to the due diligence activities of third-party components to be implemented and integrated into the product from 7.10.

7.5.3 Requirement

[CLA-04-RQ-01] The product shall be developed and maintained in a secure manner to prevent unauthorised changes through the use of a secure development environment.

[CLA-04-RQ-02] All cybersecurity requirements 7.3 as per the cybersecurity architecture and design 7.4 shall be implemented in the product.

[CLA-04-RQ-03] The list of components integrated in the product shall be identified and maintained.

NOTE 1 Identification of the components can, for example, follow the activities defined in [Error! Reference source not found.](#) Clause 5.3.8.

[CLA-04-RQ-04] An SBOM appropriate for the product shall be created and maintained.

NOTE 2 For example, follow the activities defined in [Error! Reference source not found.](#) Clause 5.3.8.

[CLA-04-RQ-05] The technical documentation shall be prepared.

[CLA-04-RQ-06] The information and instructions to the user shall be prepared.

[CLA-04-RQ-07] If the secure implementation activities result in deviations from the cybersecurity architecture and design documentation, reviews of the cybersecurity risk management activities (as per 6.7) and impacted cybersecurity product lifecycle activities shall be triggered.

7.5.4 Output

The output of secure implementation shall include:

- documentation on how the development and maintenance of the product is protected from unauthorised changes;
- product with implemented cybersecurity architecture and design, including its hardware, software, and remote data processing solutions;
- list of components integrated into the product;
- an SBOM in a commonly used machine-readable format, for example as per [Error! Reference source not found.](#) Clause 5.3.8, in a manner consistent with the risks, design and scope of the product;
- when integrating third-party components, documentation confirming adherence to the components' intended purpose and user instructions;
- technical documentation and information and instructions to the user;
- updated cybersecurity risk management activities and impacted cybersecurity product lifecycle activities, if applicable.

7.5.5 Assessment criteria

Check that the output of the secure implementation from 7.5.4 exists.

Assess whether the output from 7.5.4 meets the requirements from 7.5.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

7.6 Cybersecurity verification and validation

7.6.1 Rationale and guidance

The goal of cybersecurity verification and validation (V&V) is to ensure that the concept, design and implementation of a product satisfy all respective cybersecurity requirements from 7.3.4, and that the implemented cybersecurity controls are effective.

NOTE 1 The cybersecurity verification and validation (V&V) activities focus only on the verification and validation of the product with regards to cybersecurity. Regulatory conformance assessment is not in the scope of this activity.

Cybersecurity V&V is crucial for detecting potential cybersecurity defects (such as coding mistakes, configuration errors, or design flaws) that could be exploited by malicious actors. Resolving uncovered vulnerabilities can reduce the risk of successful cyberattacks.

Cybersecurity V&V is a recurring activity integrated throughout the entire lifecycle, not only at the final development stages. Cybersecurity V&V often uncovers implementation issues that can trigger design changes; therefore, these activities are normally repeated until the relevant cybersecurity issues are addressed. Cybersecurity V&V is usually carried out whenever the product changes, such as during maintenance or after resolution of newly uncovered vulnerabilities, and may be carried out whenever a product undergoes substantial modification.

Cybersecurity V&V activities often include but are not limited to the following approaches:

- Cybersecurity analysis: a systematic evaluation process in which cybersecurity-related artefacts, such as architecture and design documentation, user and technical documentation, and code, drawings and schematics, are examined. This activity can include static and dynamic code analysis techniques, inspections, and peer reviews undertaken to determine the suitability, adequacy, and effectiveness of the artefacts in achieving the cybersecurity requirements.

NOTE 2 Cybersecurity analysis can be done manually or automatically.

- Vulnerability scanning: involves identifying and assessing vulnerabilities in the software and hardware components used in the product. It can involve scanning the product with specialized tools to detect cybersecurity defects by querying vulnerability databases, or identification of typical indicators for specific defect classes.

NOTE 3 For more information on vulnerability scanning, refer to 7.8.

- Hardware cybersecurity testing: assessment of the robustness of hardware against physical attacks. This can include testing side-channel countermeasures, testing resistance to fault injection (such as voltage, clock, or electromagnetic), and verification that debug interfaces are disabled in manufacturing.

Where appropriate to the risks, design and scope of the product, the following testing techniques can be used as part of cybersecurity V&V activities:

- Functional testing: Conformance testing that verifies whether the actual implementation complies with the defined cybersecurity requirements. This type of testing focuses on the correct implementation of the cybersecurity controls.
- Unit testing: focuses on verifying that functional units of software behave securely and as intended. It is considered a best practice in software development to implement software as testable units and to write corresponding unit tests for each. Unit tests support regression testing, provide living documentation of expected behaviour, facilitate integration, and encourage good design.
- Integration testing: Performed to verify the interaction between different components and identify any cybersecurity gaps that can arise;
- System testing: Evaluates the overall cybersecurity of the product and its cybersecurity features, including its resilience to various attack scenarios;
- Fuzz testing (Fuzzing): Involves subjecting the product or its components to a wide range of unexpected, random, or invalid inputs in order to detect vulnerabilities and software defects, such as crashes, memory leaks, or unexpected behaviour.
- Stress testing: Involves stressing the product during runtime to evaluate how it handles resource usage and demand. These tests often reveal issues such as denial-of-service vulnerabilities, memory leaks, or inefficient resource handling.
- Penetration testing: Involves performing purposeful attacks on the product with different levels of pre-existing knowledge to identify vulnerabilities and assess the product's ability to withstand them;

It is a common practice to ensure that the testing environment is secure. Where possible, carry out cybersecurity V&V in an isolated environment.

NOTE 4 Cybersecurity V&V documentation can include up-to-date test strategy documentation containing information for verification and validation activities, including but not limited to, what to test (e.g., interface lists, security controls, cryptography solutions), when to test (e.g., yearly, per release, when to re-test) and how to test (e.g., tools, methods). This approach allows for a comprehensive approach for V&V activities and can be used to track effectiveness, provide evidence for internal and external entities and enable continuous improvement.

7.6.2 Input

The input shall, at the appropriate development phases, include:

- product with implemented cybersecurity architecture and design, including its hardware, software, and remote data processing solutions from 7.5.4;
- technical documentation and information and instructions to the user; from 7.5.4;
- the cybersecurity requirements from 7.3.4;
- the product cybersecurity context from 6.2.4;
- previous cybersecurity V&V results, where applicable.

7.6.3 Requirement

[CLA-05-RQ-01] Cybersecurity V&V shall verify that the cybersecurity controls implemented in the product fulfil the intended cybersecurity requirements 7.3.4.

[CLA-05-RQ-02] Cybersecurity V&V shall validate that the product 7.5.4 is secure within its context 6.2.4 according to the risk assessment 6.4.

[CLA-05-RQ-03] Cybersecurity V&V activities shall, where appropriate to the design, risk assessment and cybersecurity context of the product, include the following activities:

- Analyse that the product implementation artefacts, including those for integrated components fulfil the cybersecurity requirements;
- Validate that the implemented design handles errors, including input data validation;
- Verification and validation of the external interfaces and protocols within the cybersecurity context of the product;
- Perform additional security testing to discover cybersecurity vulnerabilities in the product. This may include penetration testing;
- Review the cybersecurity technical documentation and information and instructions for accuracy and completeness;
- Verify that the applicable risk treatments align with the cybersecurity requirements.

[CLA-05-RQ-04] Cybersecurity V&V shall be performed as recurring activities aligned with 7.8.

[CLA-05-RQ-05] Cybersecurity V&V shall confirm that cybersecurity risks from integrated components have been addressed in the implemented design.

[CLA-05-RQ-06] Cybersecurity V&V shall identify the selected test methods used in the cybersecurity V&V activities.

7.6.4 Output

The output shall include:

- documentation of the cybersecurity V&V results (e.g. test reports) including the test methods selected.

7.6.5 Assessment criteria

Check that the output of the cybersecurity V&V from 7.6.4 exists.

Assess whether the output of the cybersecurity V&V from 7.6.4 meets the requirements from 7.6.3.

Assess if evidence exists that the cybersecurity controls implemented fulfil the cybersecurity requirements 7.3 and are aligned with the product's cybersecurity context 6.2.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

7.7 Secure production and distribution

7.7.1 Rationale and guidance

Secure production and distribution activities ensure that the cybersecurity risks associated with production (including manufacturing) of and distribution of the product are managed until the product is placed on the market.

For software products delivered digitally, and where appropriate to the risks, this can include ensuring that the integrity and authenticity of the software is protected.

For hardware products, or software products placed on the market with a hardware component, measures are needed to ensure that the components and data are protected from manipulation during the secure production activities, until the product is made available on the market.

A secure production control plan can support secure production activities. The secure production control plan often includes, but is not limited to:

- cybersecurity-relevant instructions that the manufacturer follows to securely produce the product;
- cybersecurity measures to prevent unauthorized alteration of the product during production, considering:
 - physical access to production servers or production stations holding software;
 - cryptography, where appropriate;
 - cybersecurity configuration settings, and/or access controls.
- methods to confirm that the product is produced according to the cybersecurity requirements.

7.7.2 Production and distribution of digital software products

7.7.2.1 Rationale and guidance

Production and distribution of digital software products relates to activities for the distribution of software products and software updates, including compiling, building, packaging, and preparing software artefacts for distribution through digital channels.

NOTE 1 Software distribution also applies to software updates for hardware products. For certain product categories, such updates are commonly referred to as firmware updates.

The activities as part of the production and distribution of digital software products reduce the risk of products being manipulated by external actors during software distribution (for instance, via an online hosting platform such as an app store).

Information and instructions to the user, when shared digitally, are also in the scope of production and distribution of digital software products.

NOTE 2 A cybersecurity assessment of the digital distribution channel (e.g. online hosting platform or manufacturer's download site) can be used to determine the suitability of the hosting location. Where issues are uncovered, these can be managed as part of the product cybersecurity risk assessment activities 6.4.

7.7.2.2 Input

The input shall, where applicable, include:

- software products including:
 - artefacts used for distribution of the software product, such as software images, update packages, binaries, other digital data;
 - supplementary documentation, including information and instructions to the user.

7.7.2.3 Requirement

[CLA-06-RQ-01] Production and distribution of digital software products shall ensure that software products and software updates, distributed using software images and other distribution artefacts, are protected from manipulation, considering both when artefacts are in transit and when artefacts are stored.

[CLA-06-RQ-02] The activities of production and distribution of digital software products shall, where appropriate to the risk assessment and cybersecurity context of the product, include the following measures:

- Authentication for accessing protected areas of the online hosting platform;
- Protection of the integrity of distribution artefacts, considering both transit and storage;
- Mechanisms that ensure the authenticity of distribution artefacts.

[CLA-06-RQ-03] Information and instructions for the user shall be protected during distribution. This includes the communication channels of the information and instructions for the user.

[CLA-06-RQ-04] The information and instructions for the user shall be made available in an accessible manner.

7.7.2.4 Output

The output shall include:

- software product distribution artefacts ready to be securely made available on the market;
- where appropriate to the risk assessment and cybersecurity context of the product, documentation of the measures used for authentication and to protect the authenticity and integrity of the distribution artefacts;
- where applicable, documentation of how the communication channel for the information and instructions to the user is made secure and accessible.

7.7.2.5 Assessment criteria

Check that the output of the secure digital production from 7.7.2.4 exists.

Assess whether the output of the secure digital production from 7.7.2.4 meets the requirements from 7.7.2.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled

7.7.3 Production and distribution of physical products

7.7.3.1 Rationale and guidance

Production and distribution of physical products relates to the production of tangible products, such as products placed on the market with a hardware component or using physical media (such as a memory card or a compact disc).

Activities in the scope of this clause reduce the risk that the production process is manipulated by external actors.

Consider the following aspects, where applicable, for a secure production and production environment:

- change management activities to ensure process changes are verified for cybersecurity impact;
- protection of systems and processes used in manufacturing the product;
- protection of any data supporting the secure manufacturing activities;
- tamper-resistance or tamper-evidence for packaged products.

7.7.3.2 Input

The input shall, where applicable, include:

- digital data for production (e.g. software package, binary, configuration file);
- product cybersecurity requirements for manufacturing (7.3).

7.7.3.3 Requirement

[CLA-07-RQ-01] The risks arising from any product with a hardware component or using physical media being manipulated or altered by unauthorized actors during the manufacturing process shall be addressed.

[CLA-07-RQ-02] The activities as part of production and distribution of physical products shall, where appropriate to the risk assessment and cybersecurity context of the product, include the following measures:

- protection of the confidentiality, authenticity and integrity of work instructions for operators involved in production activities;
- verification of expected product components and their associated firmware, software or other data as part of production activities;
- based on the defined security controls, protection for confidentiality, authenticity and integrity of installed software, data or configurations (e.g. cybersecurity settings, keys, identifiers, advisories) within or transmitted to or from the manufacturing environment, including ensuring that programming and testing features on an embedded device are restricted from unauthorized use;
- protection and authentication management of cybersecurity features used in the product (e.g. PKI management).

7.7.3.4 Output

The output shall include evidence of the activities undertaken as per 7.7.3.3.

7.7.3.5 Assessment criteria

Check that the output of the secure physical production from 7.7.3.4 exists.

Assess whether the output of the secure physical production from 7.7.3.4 meets the requirements from 7.7.3.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

7.8 Product cybersecurity monitoring and issue management

7.8.1 Rationale and guidance

Cybersecurity issues include vulnerabilities and incidents affecting the product including its RDPS.

Monitoring the threat landscape of a product is essential for responding to changes and for detecting new vulnerabilities, which in turn supports the prevention of incidents.

The aim of product cybersecurity monitoring is to identify cybersecurity-related issues during the product lifecycle. It typically includes identifying, receiving, and processing, where applicable, cybersecurity-related issues from internal and external sources throughout the different phases of the product lifecycle.

NOTE 1 Monitoring can help identify changes in the product's threat landscape.

NOTE 2 Monitoring can include monitoring of vulnerability databases, end of support notices for integrated components, and other sources of vulnerability reports, either manually or through automated means.

NOTE 3 Additional insights can be gathered from cybersecurity laboratories, from similar products on the market or from market surveillance authorities.

Cybersecurity issue management activities include ensuring that cybersecurity issues can be identified, handled and resolved for the product. These activities are a key aspect of the maintenance of a product.

NOTE 4 Product cybersecurity monitoring and issue management activities can be supported by activities further specified in [Error! Reference source not found.](#), including documentation requirements, periodic testing and review, disclosure requirements and other obligations.

7.8.2 Input

The input shall, where applicable, include:

- documentation relevant to communication from 6.6;
- risk related documentation from 6.4;
- internal and external sources for collecting information about product related cybersecurity incidents, including reports provided through third-party vulnerability disclosure;

— verification and validation documentation from 7.6.

7.8.3 Requirement

[CLA-08-RQ-01] The manufacturer shall monitor for changes in the product's risk assessment, (Clause 6.4), including incidents and vulnerabilities, at periodic intervals justifiable for the product context. Monitoring may follow, for example, the activities described in [Error! Reference source not found.](#)

[CLA-08-RQ-02] The risk assessment from Clause 6.4 shall be updated, if needed.

[CLA-08-RQ-03] Discovered vulnerabilities shall be addressed in line with Clause 6.4 and 6.6. Vulnerability handling may follow, for example, the activities described in [Error! Reference source not found.](#)

[CLA-08-RQ-04] Verified cybersecurity incidents shall be addressed without undue delay where appropriate to the risk assessment and cybersecurity context of the product.

[CLA-08-RQ-05] Relevant residual risk as a consequence of the cybersecurity incident shall be communicated in alignment with Clause 6.6.

7.8.4 Output

The output shall include documentation demonstrating the periodic intervals at which the manufacturer will check for changes in the risk assessment, including a justification for the periodic intervals.

The output shall include evidence demonstrating the activities undertaken as a result of monitoring the product's risk assessment.

Where a cybersecurity incident or vulnerability for the product has been identified, the output shall include:

- the risk assessment result;
- evidence that the incident or vulnerability has been treated without undue delay, where appropriate to the risk assessment and cybersecurity context of the product.

7.8.5 Assessment criteria

Check that the output of the product cybersecurity monitoring and issue management from 7.8.4 exists.

Assess whether the output of the product cybersecurity monitoring and issue management from 7.8.4 meets the requirements from 7.8.3 .

In case an incident has occurred, assess whether the treatment decision of the output from 7.8.4 appropriately resolves the root cause of the incident.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

7.9 Planning for secure decommissioning

7.9.1 Rationale and guidance

Planning for secure decommissioning is the activity preparing for securely resetting or retiring a product, including its RDPS, ensuring the user's assets are not compromised when the product changes user or when it is disposed of at the end of its operational life. Typically, this relates to the secure deletion of the user's assets, such as user related data, settings and cryptographic keys, as well as resetting a product into a secure default state. Decommissioning is covered by [Error! Reference source not found.](#)

Once a product and its included RDPS reach the end of their support period there can be other obligations to inform the users about the end of the support period and the potential impact on the continued use of the product. It is essential that this information is communicated in clear, simple, and accessible language as outlined in Clause C.7. Accounting for this aspect of decommissioning and any activities the manufacturer has remaining at and beyond the end of the support period is part of the planning for secure decommissioning.

NOTE 1 An RDPS might be integrated in multiple products. Decommissioning focusses on the removal of the user data, where appropriate to the context of the product. In some cases, decommissioning of the product warrants the deletion of user data on the RDPS, in other cases it might not. In any case, informing the user about how to securely remove their data is best practice.

NOTE 2 Decommissioning or the reset to a secure default is done only by authorized users. Not all users might be authorized users. This depends on product context.

7.9.2 Input

The input shall include:

- the product context from 6.2.4;
- the product assets from 6.4.2.4;
- the product architecture and design from 7.4.4.

7.9.3 Requirement

[CLA-09-RQ-01] The manufacturer shall prepare for the secure decommissioning of the product, accounting for at least:

- cybersecurity considerations to be taken into account for decommissioning;
- the confidential assets, such as user related data, settings and cryptographic keys, that need to be securely deleted and where those are logically located;
- where a third-party or the manufacturer is operating parts of the product, appropriate actions to ensure the product can be securely decommissioned;
- relevant information and instructions to the user regarding decommissioning;
- the method by which the user is informed about the decommissioning;
- activities to be undertaken by the manufacturer to ensure the secure decommissioning of the product.

[CLA-09-RQ-02] Relevant information and instructions to the user shall contain, where applicable, at least:

- how to remove the user data (for example, by a "Factory Reset" or "Secure Erase" function);
- how to export the user data;
- how to remove cybersecurity assets, e.g. security relevant configuration data stored in the product;
- how to remove the product from its intended operational environment;
- how to securely dispose of the product to prevent potential disclosure of data contained in the product that could not be removed as described above;
- for any data removed automatically, information on what will be deleted and when.

7.9.4 Output

The output shall include:

- Documentation explaining the communication method by which the user is informed of decommissioning;
- Documentation explaining the activities to be undertaken by the manufacturer to prepare for the secure decommissioning of the product;
- Where applicable, information and instructions to the user containing the related parts of 7.9.3.

7.9.5 Assessment criteria

Check that the output of the decommissioning from 7.9.4 exists.

Assess whether the output of the decommissioning from 7.9.4 meets the requirements from 7.9.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

7.10 Third-party component cybersecurity management

7.10.1 Rationale and guidance

Third-party components, including commercial, free and open-source components, can introduce cybersecurity risks to products including remote data processing solutions.

Cybersecurity risks of third-party components are relevant because vulnerabilities in these components can compromise the cybersecurity and integrity of the product. It is important to take due diligence when selecting and incorporating third-party components.

Third-party component cybersecurity management specifies the requirements and activities to ensure that cybersecurity risks relevant to third-party components integrated into the product are handled with due diligence and other relevant activities. This includes tasks such as:

- assessing that the intended purpose and reasonably foreseeable use of the third-party component align with the use/integration within the product;

- evaluating that the third-party component is compliant with applicable legal and contractual requirements and the cybersecurity requirements in particular for the product. This can be done by, for example, checking for:
 - a CRA CE marking and EU Declaration of Conformity, if available;
 - verification that there are no known vulnerabilities that are relevant (introducing unacceptable risk) to the product registered in a (publicly available) vulnerability database, e.g. the European vulnerability database established pursuant to Article 12(2) of Directive (EU) 2022/2555 [0](#);
 - availability of cybersecurity patches;
 - vulnerability disclosure and handling;
 - a risk assessment;
 - checking if additional cybersecurity testing is required;
 - technical verification (e.g., binary analysis, source code scanning, rebuilding from source or code reviews).
- considering the support period of components when selecting them for integrating these into the product. This anticipates the risks arising from deprecated third-party component and obsolete technologies;
- assessing the risk of the third-party component and its integration in the risk assessment of clause 6.4;
- securely incorporating the third-party component according to clause 7.4 and clause 7.5;
- monitoring for vulnerabilities in the third-party component over the product lifecycle according to clause ;
- communicate newly found vulnerabilities in the third-party component as well as sharing potential solutions if available.

In order to improve overall cybersecurity, it is relevant to communicate any newly discovered vulnerabilities to the responsible third-party. This third-party can be a supplier, service provider, an open-source steward, or any party that can facilitate the handling of the discovered vulnerability of the third-party component in the product.

Information sharing about potential vulnerabilities can be managed through agreements between relevant interested parties, for example through a coordinated vulnerability handling process.

To support a culture of transparency and collective cybersecurity improvement, as well as to prevent fracturing of the Free and Open Source Software (FOSS) ecosystem, it is best practice to share with the third-party any developed fixes, or documentation for fixes, for vulnerabilities found in the third-party's component.

Upstream Contribution (submitting fixes to the original project) is a valid form of risk treatment specifically, for future product versions.

Warning — , and shall include, where applicable, the following activities:

- Assessment and verification of whether the intended purpose and reasonably foreseeable use of the third-party component is in accordance with the use/integration within the product;
- Verification that there are no known vulnerabilities;
- Checking if additional cybersecurity testing is required;
- If the third-party component is commercial check if a CE marking and EU Declaration of Conformity are available;
- If the third-party component is FOSS check if:
 - the FOSS project is actively maintained, including evidence of recent development or maintenance activity;
 - a vulnerability disclosure process is defined and publicly available;
 - the FOSS is stewarded for commercial use by a foundation or organization acting as an open-source software steward;
 - there are indicators of cybersecurity-by-design practices, such as documented secure development practices;
 - regular cybersecurity patches or security updates are made available.

NOTE 1 To ensure that all necessary and distributed cybersecurity activities related to third-party components are clearly assigned and agreed, manufacturers are advised to align responsibilities with their suppliers and document it before bringing a product to the market. This supports implementation of the requirements outlined in the requirement subclause **7.10.3** and promotes consistent collaboration across the supply chain.

NOTE 2 The manufacturers are advised to adjust their activities taking into account the nature of open source third party components. Open source components' source code is available to the manufacturer and the quality of the code as well as the development activity could be assessed by the manufacturers. At the same time, entering into support arrangements with providers of open source components may be impossible, but third party expertise could be available.

7.10.2 Input

The input should include documentation of third-party components used in the product including:

- an SBOM of the third-party component;
- the Declaration of Conformity (also mentioning the standard used for this purpose), of the third-party component;
- the intended purpose and reasonably foreseeable use of the third-party component.

7.10.3 Requirement

[CLA-10-RQ-01] Due diligence shall be performed for third-party components during the selection and prior to the integration into products.

[CLA-10-RQ-02] Third-party components and their integration shall be included in the risk assessment and treatment activities contained in Clause 6;

[CLA-10-RQ-03] Third-party components shall be securely implemented and integrated as aligned with 7.5.

[CLA-10-RQ-04] Third-party components and their integration shall be validated and verified in accordance with 7.6;

[CLA-10-RQ-05] Third-party components shall be monitored over their lifecycle to identify and address relevant vulnerabilities for the product according to 7.8.

7.10.4 Output

The output shall include documented evidence that the relevant activities mentioned in 7.10.3 have been performed.

7.10.5 Assessment criteria

Check that the output from 7.10.4 exists.

Assess whether the output from 7.10.4 meets the requirements from 7.10.3.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

Annex A

(informative)

Coherence with vertical standards

A.1 Coherence elements for vertical standards

The development of vertical standards for specific (groups of) products with digital elements that seek coherence with the framework established by this document can:

- align with the terminology provided in the vocabulary [Error! Reference source not found.](#) of the framework;
- apply the cybersecurity principles provided in Clause 5;
- perform management of cybersecurity risks described in Clause 6 to identify and provide appropriate technical specifications for products with digital elements and assessment methodologies incl. assessment criteria addressing, based on identified risks, the essential cybersecurity requirements of CRA ANNEX I Part I [0](#);
- apply the vulnerability handling processes addressing the essential cybersecurity requirements of CRA ANNEX I Part II [0](#) provided in [Error! Reference source not found.](#).

Annex B (informative)

Relationship between this European Standard and the essential cybersecurity requirements of Regulation (EU) 2024/2847

B.1 Rationale and guidance

This European Standard has been prepared under a Commission's standardization request M/606 C(2025) 618 final to inform on voluntary means of conforming to essential cybersecurity requirements of Regulation (EU) 2024/2847 [OJEU L 60] [0](#).

B.2 Reference to essential requirements

This document has been prepared with the intention to support compliance with the Annex A of Regulation (EU) 2024/2847. Table B.1 describes the relationship of compliance with the normative clauses of this document and the corresponding essential cybersecurity requirements of that Regulation.

B.3 Mapping to essential requirements

Table B.1 contains the relationship of the essential requirements to the clauses of this document.

7.3-7.7 are the implementation and testing of the controls that ensure Clause 6 is done properly.

The scope of the standardization request extended the scope of the ER Part I (1). In line with the CRA, the standardisation request clarifies that the scope of the manufacturer cybersecurity risk assessment extends to the planning, delivery and maintenance of the product. Elements of these are considered in 7.2 (product cybersecurity planning), 7.8 (product monitoring), 7.9 (decommissioning), and 7.10 (third-party component cybersecurity management).

For completeness decommissioning was added in 7.9 as decommissioning is part of the product lifecycle.

**Table B.1 — Relationship between this European Standard and Annex I of Regulation
2024/2847 [OJEU L 60]**

Essential Cybersecurity Requirements of Regulation 2024/2847	Clause(s)/sub-clause(s) of this EN	Remarks/Notes
Part I (1). Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.	Designed: 7.4 Developed: 7.5 Produced: 7.7 Appropriate level: 6.3 Based on risk: Clause 6, 7.3 Ensure – 7.6	Conformance to the requirements of this clause supports in identifying properties of a product to satisfy this essential cybersecurity requirement
ANNEX I Part I (2). On the basis of the cybersecurity risk assessment referred to in Article 13(2) and where	Based on the risks: Clause 6, 7.3	Product controls to ensure compliance with the essential

applicable, products with digital elements shall:	Products with digital elements shall: inferred in Clause 7, 7.3	cybersecurity requirement Part 1 (2) can be found in Error! Reference source not found.
ANNEX I Part I (2) (a). On the basis of the cybersecurity risk assessment referred to in Article 13(2) and where applicable, products with digital elements shall be made available on the market without known exploitable vulnerabilities;	Known exploitable vulnerabilities: 6.4.3.2, 7.6.3	This document requires that known exploitable vulnerabilities in the product context are appropriately managed (treated and communicated).
ANNEX I Part I (2) (b) be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state	Be made available with a secure by default configuration: 7.4 Unless otherwise agreed: 6.3 contractual agreements	
ANNEX I Part I (2) (c). ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them	Vulnerabilities can be addressed: 7.8 Security updates: 7.2, 7.8.3 Appropriate timeframe: 7.8.3	
ANNEX I Part I (2) (d) ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;	Ensure protection from unauthorised access by appropriate control mechanisms: 7.4, 7.5, Report on possible unauthorised access: 7.4,7.8 Protection: inferred in 7.4 Reporting: inferred in 7.4	
ANNEX I Part I (2) (e) protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means	Protect the confidentiality of stored, transmitted or otherwise processed data: 7.4, 7.6,	
ANNEX I Part I (2) (f) protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not	Protect the integrity of stored, transmitted or otherwise processed data: 7.4, 7.6, Report on corruptions: 7.8	

authorised by the user, and report on corruptions		
ANNEX I Part I (2) (g) process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation)	Process only data that are adequate, relevant and limited to what is necessary: 7.4	
ANNEX I Part I (2) (h) protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks	Protect the availability of essential and basic functions, also after an incident: 7.4 Mitigation measures against denial-of-service attacks: 7.4 Protection: inferred in 7.4 Protection after incident: inferred in 7.4 Measures against DoS: inferred in 7.4	
ANNEX I Part I (2) (i) minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks	Minimise the negative impact by the products themselves: 7.4 Minimise the negative impact on connected devices: inferred in 7.4	
ANNEX I Part I (2) (j) be designed, developed and produced to limit attack surfaces, including external interfaces;	Be designed, developed and produced to limit attack surfaces: 7.4 Limit surface: inferred in 7.4	
ANNEX I Part I (2) (k) be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques	Be designed, developed and produced to reduce the impact of an incident: 7.4, 7.6 Reduce impact: inferred in 7.4 and 7.6	
ANNEX I Part I (2) (l) provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user	Provide security related information by recording and monitoring relevant internal activity: 7.4, 7.6 With an opt-out mechanism for the user: 7.4	
ANNEX I Part I (2) (m) provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner	Provide the possibility for users to securely and easily remove on a permanent basis all data and settings: inferred in 7.9	
ANNEX I Part II (1) identify and document vulnerabilities and components contained in products with digital elements, including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very	SBOM covering top-level dependencies: 7.5	

least the top-level dependencies of the products;		
ANNEX I Part II (2) in relation to the risks posed to products with digital elements, address and remediate vulnerabilities without delay, including by providing security updates; where technically feasible, new security updates shall be provided separately from function updates;	Without undue delay: 7.8	
ANNEX I Part II (3) apply effective and regular tests and reviews of the security of the product with digital elements	Regular review of the risk: 6.7. Establishing the regularity with which to test: 7.2. Regular testing for V&V: 7.6.	
ANNEX I Part II (4) once a security update has been made available, share and publicly disclose information about fixed vulnerabilities, including a description of the vulnerabilities, information allowing users to identify the product with digital elements affected, the impacts of the vulnerabilities, their severity and clear and accessible information helping users to remediate the vulnerabilities; in duly justified cases, where manufacturers consider the security risks of publication to outweigh the security benefits, they may delay making public information regarding a fixed vulnerability until after users have been given the possibility to apply the relevant patch	Disclosure: 7.8	
ANNEX I Part II (5) put in place and enforce a policy on coordinated vulnerability disclosure	CVD implied in 7.10	
ANNEX I Part II (6) take measures to facilitate the sharing of information about potential vulnerabilities in their product with digital elements as well as in third-party components contained in that product, including by providing a contact address for the reporting of the vulnerabilities discovered in the product with digital elements	Information sharing with third-parties: 7.10	
ANNEX I Part II (7) provide for mechanisms to securely distribute updates for products with digital elements to ensure that vulnerabilities are fixed or mitigated in a timely manner and, where applicable for security updates, in an automatic manner;	Secure distribution: 7.7 Vulnerabilities fixed in a timely manner: 7.8	

ANNEX I Part II (8) ensure that, where security updates are available to address identified security issues, they are disseminated without delay and, unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital elements, free of charge, accompanied by advisory messages providing users with the relevant information, including on potential action to be taken	Unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital elements: inferred in 6.3.2 (contractual agreements)	
--	---	--

B.4 Normative or informative

Due to the horizontal nature of this document not all parts can be normative. However the informative parts of this document contain a variety of best practices and suggestions that if applicable are best implemented. Table B.2 displays which parts of the document are normative.

Table B.2 — Normative status of the structure of each clause

Clause number	Subclause structure	Normative or informative
Clause 5	Principle	Informative
	Guidance	Informative
Clause 6 and Clause 7	Rationale and guidance	Informative
	Input	Normative
	Requirement	Normative
	Output	Normative
	Assessment criteria	Normative

B.5 Assessment criteria

The assessment required in this document are generic and high level. They refer to the output of the clauses, typically in the form of some manner of documentation. They check for the existence of the documentation and verify that the documentation covers the requirements of the related activities.

The assessment criteria of this document therefore do not guarantee compliance with the CRA / regulatory requirements. Manufacturers may need to use applicable vertical standards or provide a justified control selection for the relevant product category in order to claim presumption of conformity.

Annex C

(informative)

Accessible and inclusive cybersecurity

C.1 Scope

This annex focuses on enabling manufacturers of consumer cyber products to produce products which are both secure and accessible to the users.

C.2 Rationale

The European Accessibility Act (EAA) [0](#) requires that a wide range of products and services, including smartphones, ATMs, e-commerce platforms, and e-readers, are usable by persons with disabilities. This aligns with the EU's commitment to equal participation in society and the economy, ensuring that no consumer is excluded from the digital marketplace.

Security features are often the “front door” to a digital product. If a consumer cannot navigate authentication, password recovery, cybersecurity configurations, or consent dialogues, they can be left vulnerable—or unable to use the product at all. Accessibility in cybersecurity is therefore both a compliance issue under the EAA and a trust issue for manufacturers who want to serve the widest possible market.

At the same time, the CRA [0](#) places obligations on manufacturers to safeguard the cybersecurity of all users. Devices and digital services are increasingly interconnected, and secure design is essential to protect consumers from fraud, identity theft, and misuse of personal data. Therefore it is important that, cybersecurity itself is accessible by all—otherwise they can inadvertently exclude or disadvantage certain groups of users. Cybersecurity that is accessible, inclusive and easy to use in turn benefits all users.

Accessibility and cybersecurity are two sides of the same coin: both protect users, both reduce exclusion, and both are essential for building a sustainable digital economy.

C.3 The user

Cybersecurity is often designed with the “ideal user” in mind. This ideal user has a limitless memory and attention to detail, to enable them to be fully aware of system behaviours that indicate suspect behaviours and the ability to retain and apply all the rules in organization policies. Very few humans have all these abilities all of the time. This is why it is crucial to create a good understanding of what can be reasonably expected of the user demographics, as otherwise many potential users will struggle and may fail to use the product safely.

When developing cybersecurity solutions, it is required to consider the user abilities and skills needed to carry out the required interactions with the product. Consumers will be impacted depending on:

- The nature of the required interaction;
- The consequence of the interaction method on the user's cybersecurity;
- The recommended solution to ensure maximum cybersecurity to the potential users.

Limiting the types of users who can interact with a product will harm people with disabilities and also people with temporary conditions caused by accident, illness, stress, grief or distraction.

C.4 Nature of the required interaction

The nature of the required interaction can include (but is not limited to) the following:

- The use of visual or audible information that can reduce the cybersecurity for blind/visually impaired/colour-blind and/or deaf/hard of hearing people;
- The operation of physical controls that can reduce the cybersecurity for people with gross or fine motor control issues, reach issues and/or related issues;
- The understanding of spoken or written information that can reduce the cybersecurity for people who cannot read or understand a particular language or who have a cognitive disability,
- Speech control that can reduce the cybersecurity for people who are speech impaired.

C.5 Consequences of the interaction method on the user's cybersecurity

Examples of accessibility issues in cybersecurity requirements include systems which require people to have specific physical, visual, hearing, memory or cognitive skills. Examples of these are presented with possible solutions below:

- Systems that time-out too quickly during password entry can disadvantage users who rely on assistive technologies such as screen readers or switch devices. Extending the time-out will also benefit other users including those with physical disabilities or whose attention is limited by stress.
- Biometric authentication, as facial recognition can fail for users with certain physical disabilities or conditions that affect their appearance or ability to stay still or who are using a system without a camera (or fingerprint sensor). Offering multiple authentication methods will enable more consumers to authenticate themselves. All single method verification methods can cause issues:
 - SMS-based codes can be inaccessible to people with hearing loss if voice call verification is the only backup;
 - CAPTCHA challenges relying on distorted text or images exclude users with visual loss unless multiple, accessible, alternatives (e.g., audio CAPTCHAs or logical puzzles) are provided;
 - Fingerprint scanners cannot be usable by individuals with prosthetics or reduced dexterity or whose fingerprints are not easily readable due to skin changes caused by age;
 - Pop-up alerts that disappear quickly can be inaccessible to users relying on screen readers or whose reaction times are reduced by physical factors (temporary by accident or long-term physical functional limitation or by slow reactions (caused by stress or cognitive issues or distraction by children etc.).
- Cybersecurity updates or recovery processes that depend on a single method of delivery and also use unclear terminology will be inaccessible to a range of users.

C.6 Recommended solution to ensure appropriate cybersecurity to the potential users

For each interaction, suitable alternatives can be identified for the use of different skills and abilities. Providing usable, accessible and transparent methods of interacting with the product and for communication with the user. These changes will not impact the cybersecurity of the product. User stories can be a valuable input in considering what alternatives to provide to ensure accessibility to the product.

Accessibility requirements and advice can be found in EN 301 549 [REF] “Accessibility requirements for ICT products and services”. Accounting for these requirements is better done earlier in development as adding accessibility features can also potentially add vulnerabilities and as such these need to be accounted for in the risk assessment.

C.7 Communication with the user

The obligation of the manufacturer to provide accessibility to the design of the product also extends to the accessibility of the communication with the user. This is to ensure the user is capable of accessing the information required for securely installing, operating, maintaining and decommissioning the product. By conducting heuristic evaluation, cognitive walkthroughs, and accessibility testing alongside cybersecurity testing and design analysis, manufacturers can not only reduce regulatory risk but also strengthen trust. For example, by providing alternative methods of secure access, and ensuring compatibility with assistive technologies.

For this reason, it is crucial that the information provided to the users is communicated in clear, simple, and accessible language. This applies not only to the information displayed within the product (e.g., the user interface) but also to information about the product itself (e.g., product descriptions on packaging or at the point of sale). The design of the user interface is especially critical in this context. Security-related information and settings should be presented in a way that is both intuitive and easy to understand. This includes explaining security features, options, and potential risks in a manner that does not overwhelm the user but ensures that they can make informed decisions about their security.

Annex D (informative)

Interaction of the risk management concepts and activities

D.1 Purpose of this annex

This informative annex demonstrates how the various clauses and concepts in the prEN 40000-1-2 interact with each other and with other standards in the prEN 40000-1 series.

The clauses in this standard provide the procedures that help a manufacturer to develop secure products and maintain cybersecurity during the products life cycle, thereby fulfilling the requirements of the regulation and thus support them in achieving the standardization goal. This annex helps to guide a manufacturer understand the interdependencies of the procedures, and the cyclic nature of the activities.

D.2 Interaction between clauses

The flow diagram in Figure D.1 shows the cyclic nature of the risk management activities, and how the activities covered in this standard feed into each other to create a holistic secure-by-design approach for products with digital elements.

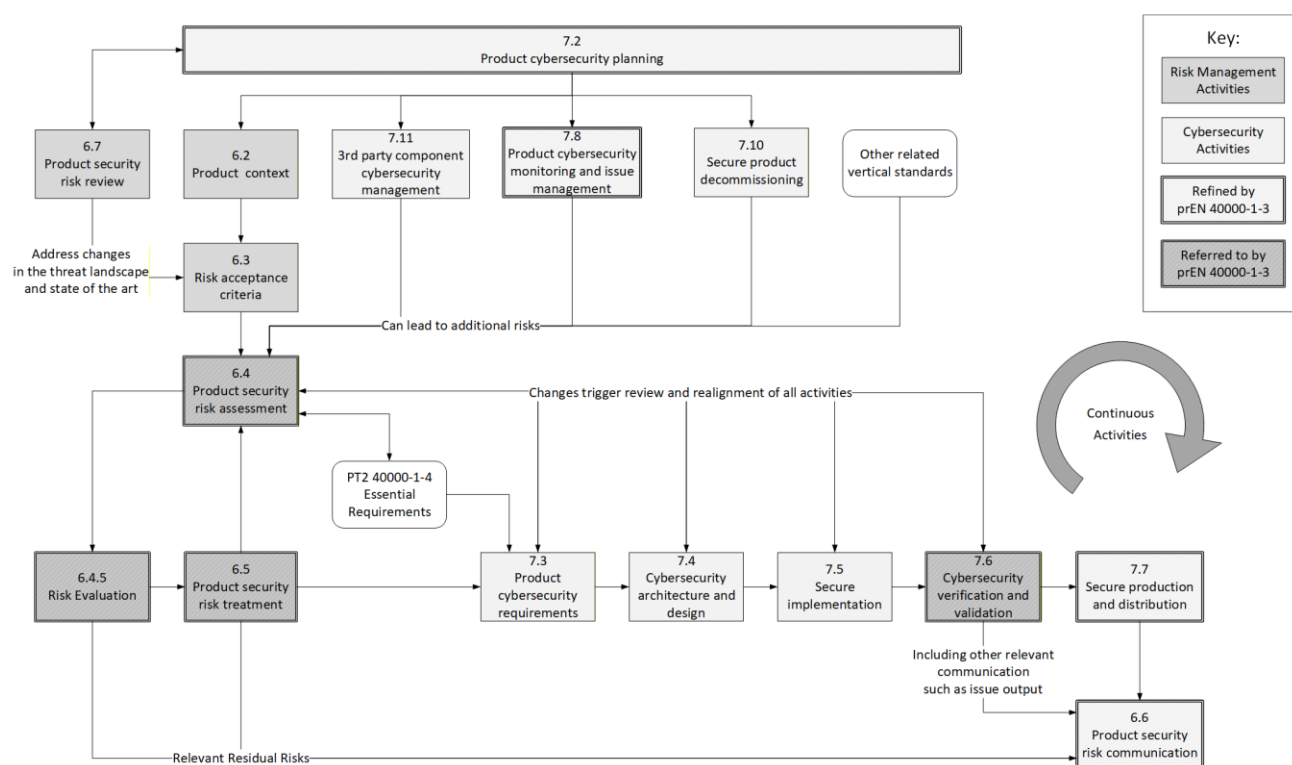


Figure D.1 — Relationships between clauses and related standards

D.2.1 Risk Management as a cyclic process

The risk management activities, as defined in Clause 6, are cyclic activities that are continually maintained throughout the product lifecycle. The flow chart demonstrates how the risk

assessment review cycle, and consequently redesign and related activities, where applicable, are triggered by:

- The regular test and review cycle as defined in 7.8
- Changes in the threat landscape or state of the art identified during the risk monitoring activities in 7.8 ;
- Product cybersecurity activities in Clause 7

As an example, the process of product monitoring (7.8) can identify vulnerabilities in components used in the product, which would trigger the risk assessment activities (6.4), and where applicable, result in updated security requirements (7.3) and redesign (7.4).

D.2.2 Relationship with other standards

Figure 1 also demonstrates how the related standards help refine the clauses in this standard. This standard, for example, provides an outline of vulnerability management activities in clauses 7.8, however the processes of vulnerability management are further refined in [Error! Reference source not found.](#)

In a similar manner, this standard also provides information used by other standards. Specifically, the activities for risk management are formally defined in this standard. Risk management concepts in the related standards (e.g. [Error! Reference source not found.](#)) include a reference to Clause 6 in this standard to provide details on the appropriate activities.

D.3 Interaction between risk management concepts

Figure D.2 illustrates the structured interaction between the key cybersecurity risk management concepts defined in Clause 6 and shows how these concepts are logically connected, from the definition of the product to the mitigation of cybersecurity risk. The figure emphasizes the traceability between technical system elements, potential cybersecurity threats, their impacts, and the measures used to address them.

- The interaction starts with the product, which operates within an operational environment that influences its exposure to threats. The product implements one or more functions and consists of components, forming the technical basis for risk identification and assessment. Within the product, assets are identified as elements of value that require protection. Each asset is characterized by specific cybersecurity properties, which define the aspects of the asset that must be preserved to prevent harm.
- To protect assets and their cybersecurity properties, cybersecurity objectives are defined. These objectives express the intended cybersecurity state of the product and establish the link between assets and potential threats. Threats represent potential causes of compromise that can violate cybersecurity objectives by compromising cybersecurity properties. When a threat is realized, it leads to a consequence, which describes the resulting harm and its impact on the end user.
- Cybersecurity risk emerges from the relationship between threats and their consequences and reflects both the likelihood of threat realization and the severity of the resulting impact. Risks are not considered in isolation but are directly traceable to the affected assets, compromised properties, and impacted end users.

- To manage and reduce cybersecurity risk, cybersecurity requirements are derived from cybersecurity objectives. These requirements are allocated to products, components, or the operational environment and are implemented to mitigate identified risks. Risk mitigation is achieved by reducing the likelihood of threat realization, limiting the severity of consequences, or both. This interaction ensures a systematic and traceable approach to cybersecurity risk management across the product lifecycle.

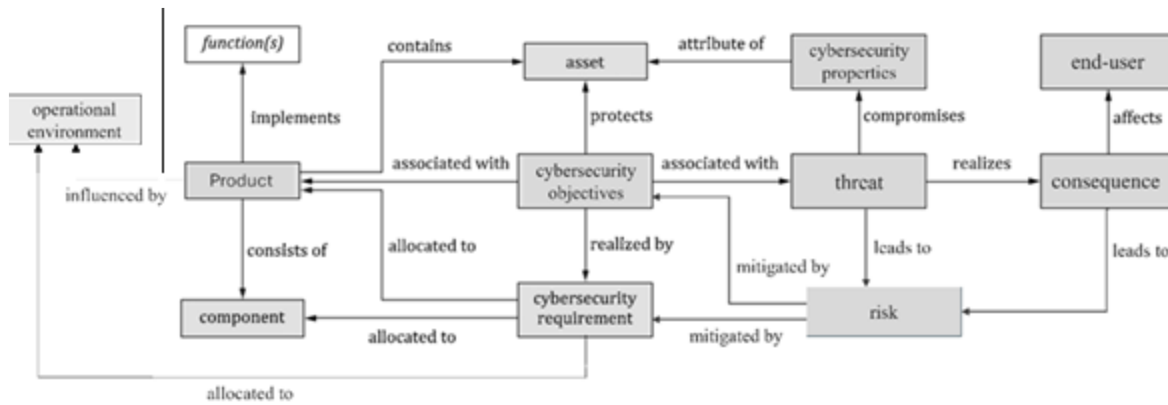


Figure D.2 — Based on ISO/SAE 21434:2021; the figure has been adapted to reflect the concepts defined in Clause 6

Bibliography

- [1] The 'Blue Guide' on the implementation of EU product rules 2022 , <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=OJ:C:2022:247:TOC>
- [2] EN IEC 62443-4-1:2018/prAA:2026, *Security for industrial automation and control systems - Part 4-1: Secure product development lifecycle requirements*
- [3] Attack Trees B. Schneier, https://www.schneier.com/academic/archives/1999/12/attack_trees.html
- [4] Risk Centric Threat Modeling, process for Attack Simulation and Threat Analysis, by Tony Uceda Vélez and Marco M. Morana
- [5] https://owasp.org/www-community/Threat_Modeling_Process#stride
- [6] ISO/SAE 21434:2021, *Road vehicles — Cybersecurity engineering*
- [7] EN IEC 62443-4-1:2018, *Security for industrial automation and control systems - Part 4-1: Secure product development lifecycle requirements*
- [8] ETSI TS 102 165-1, *CYBER; Methods and protocols; Part 1: Method and pro forma for Threat, Vulnerability, Risk Analysis (TVRA)*
- [9] JT013091:2026, *Cybersecurity requirements for products with digital elements – Generic Security Requirements*
- [10] REGULATION (EU) 2024/2847 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)
- [11] ETSI EN 303 645, *CYBER; Cyber Security for Consumer Internet of Things: Baseline Requirements*
- [12] EN IEC 62443-4-2, *Security for industrial automation and control systems - Part 4-2: Technical security requirements for IACS components*
- [13] EN ISO/IEC 15408-2:2020, *Information technology - Security techniques - Evaluation criteria for IT security - Part 2: Security functional components (ISO/IEC 15408-2:2008)*
- [14] prEN 40000-1-3, *Cybersecurity requirements for products with digital elements - Part 1-3: Vulnerability Handling*
- [15] DIRECTIVE (EU) 2022/2555 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive), <https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng>
- [16] prEN 40000-1-1, *Cybersecurity requirements for products with digital elements — Vocabulary*

- [17] DIRECTIVE (EU) 2019/882 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 17 April 2019 on the accessibility requirements for products and services, <https://eur-lex.europa.eu/eli/dir/2019/882/oj/eng>